

2025년 법령 위반 사례별 보호조치 과정 개인정보 보호 교육



Contents

#1 개인정보 보호법 위반사례와 안전조치

#2 개인정보 유·노출 사례

#3 개인정보 유·노출 예방



개인정보 보호법 위반사례와 안전조치



이슈 키워드

유출 사례

개인정보 담긴 정부시스템 수두룩... “유출은 공무원 맘먹기 나름”

공무원 A 씨는 2020년 1월부터 1101건의 개인정보를 빼돌리며 차적 조회엔 정부의 자동차관리정보시스템을, 주소 조회엔 건설기계관리정보시스템을 사용했다. 건설기계관리정보시스템은 이름과 주민번호를 넣으면 실제 면허 등록 여부와 관계없이 사실상 전 국민의 현 주민등록 주소를 조회할 수 있다. 담당 공무원은 실제 면허 발급 업무가 아니더라도 제한 없이 조회할 수 있다.

(출처: 동아일보, 2022. 1. 12)

'이석준 사건' 피해자 주소 넘긴 공무원 7년 구형...흥신소업자는 3년

신변 보호를 받던 여성의 집에 찾아가 그 가족을 숨지게 한 '이석준 사건'에서 피해자의 개인정보를 유출한 전 공무원 박모씨에게 검찰이 징역 7년형과 벌금 8천만원을 구형했습니다. 박씨에게 개인정보를 전달한 흥신소 업자 김모씨에게는 징역 3년을 구형했습니다.

(출처: JTBC, 2022. 4. 25)



접근권한 관리·감독 소홀

이슈 키워드

개인정보 침해 관련 뉴스

이젠 택배기사 계정까지...개인정보 유출경로 다각화

- 택배 기사 계정까지 매수... 고객 정보 수천 건 직접 조회
- 모텔 투숙객 불법 촬영도...개인정보 활용해 협박하려다 적발
- 경찰, 범죄 가담한 16명 모두 검거...'고객'도 수사

4,700만 건.

2018년부터 지난해 8월까지 카드사나 인터넷 기업 등에서 유출된 개인 정보 건수입니다. 유출 건수는 해마다 늘고 있습니다. 유출 경로도 다양해지고 있습니다.

이번에 경찰에 적발된 흥신소는 홈페이지 해킹뿐만 아니라 택배사와 보험사 등 고객정보를 가진 업체 직원들을 통해 약 2년간 개인정보를 빼내기도 했습니다.

(출처: KBS, 2022. 4. 19)

개인정보 침해 피해 급증



이슈 키워드

개인정보 유출 시 피해유형

신상털기

■ 개인 사생활 침해 발생

- 사귀던 애인이 SNS에 글을 올려 개인정보를 침해함에 따라 다니던 직장에서 쫓겨나거나 스토키의 표적이 될 수 있음
- 명예훼손 발생



명의로용

■ 경제적 손실

- 계좌번호, 카드번호 노출로 원치 않는 결재가 실행되어 경제적 손실 발생

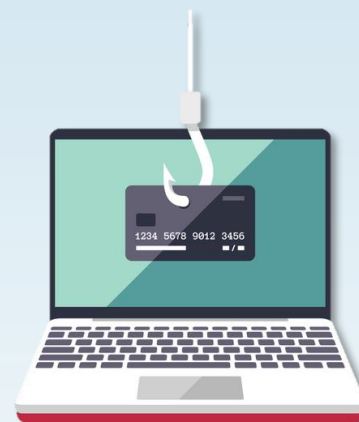
■ 정신적 피해

- 개인정보 침해로 육체적·정신적 피해 발생

보이스 피싱 또는 명의도용

■ 경제적 손실

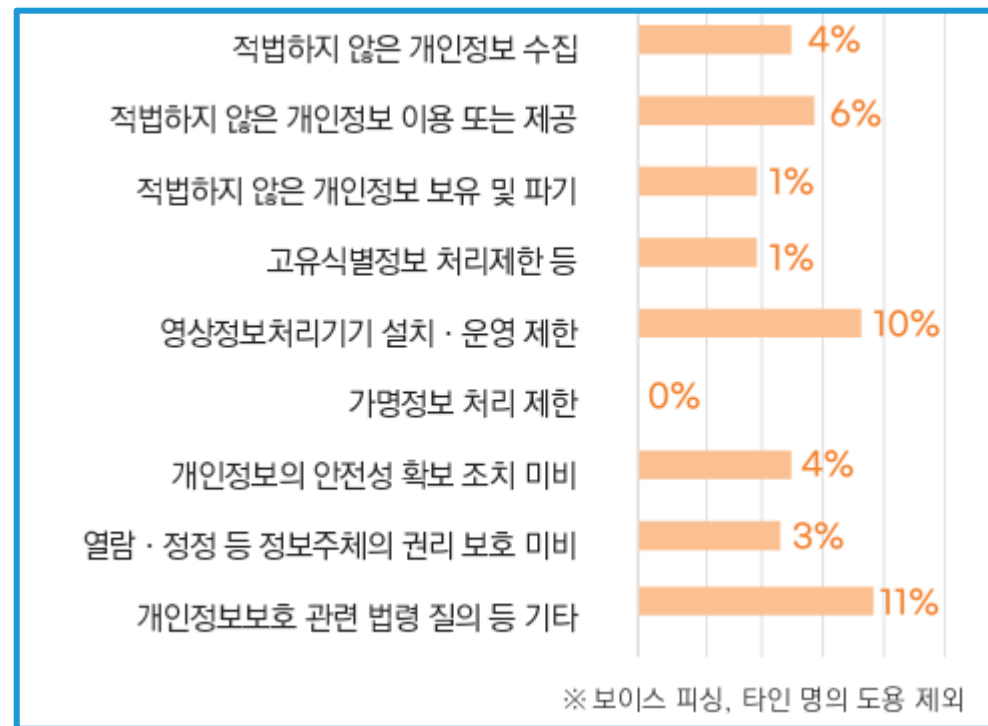
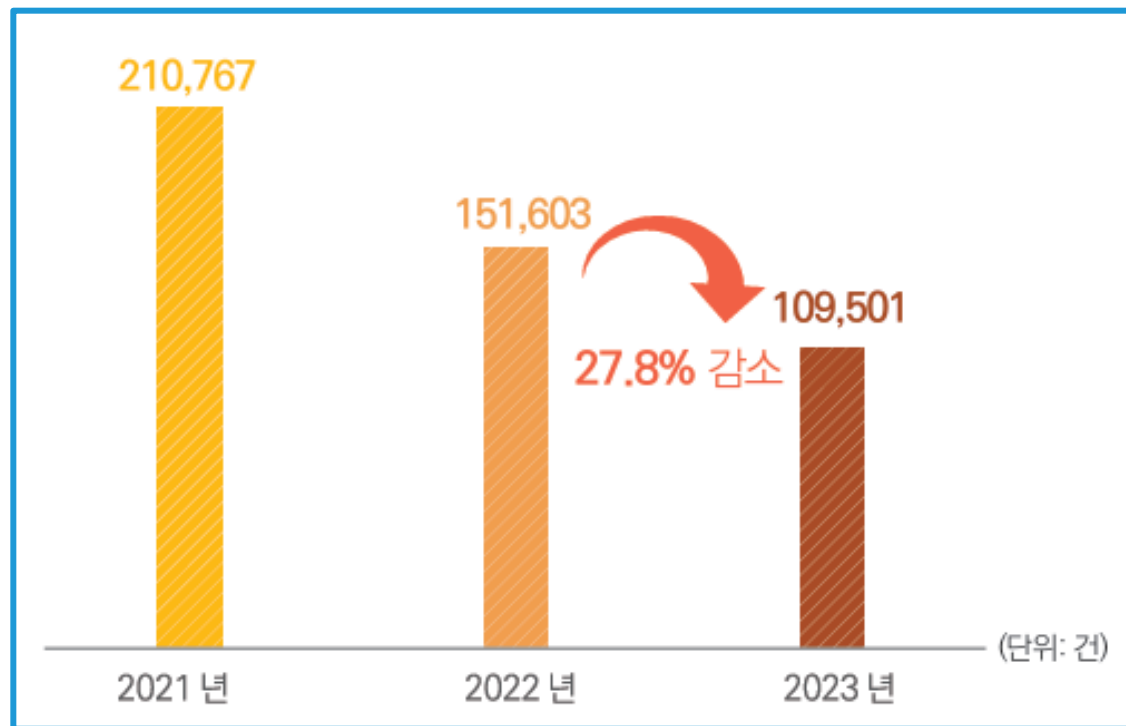
- 계좌번호, 카드번호 노출로 원치 않는 결재가 실행되어 경제적 손실 발생



이슈 키워드

[참고] 최근 3년간 개인정보 침해(상담/신고) 접수 현황

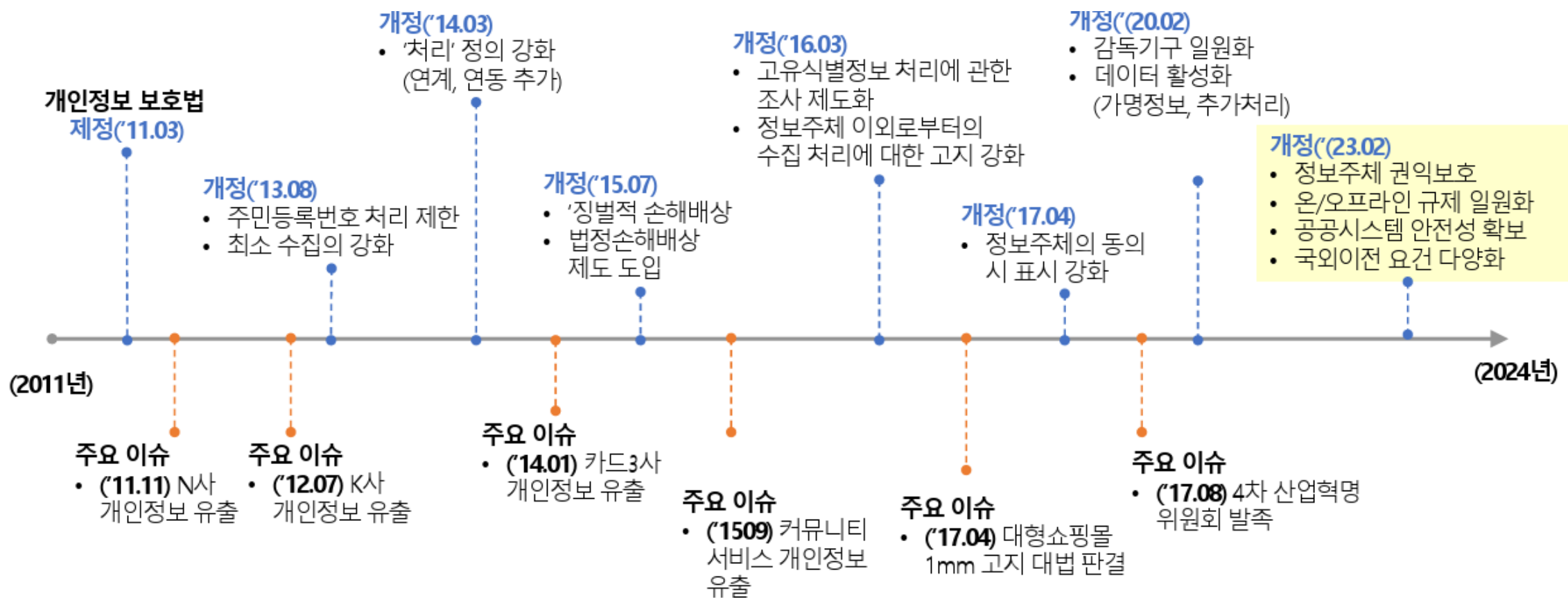
- 2023년 개인정보침해 신고·상담 건수 총 109,501건, 2022년 대비 27.8% 감소



(출처: 개인정보보호위원회, 2023 개인정보 침해현황 및 안전관리방안 안내자료)

개인정보보호법 제·개정 연혁

개인정보 사건사고와 개인정보 보호법 제·개정 연혁



개인정보보호법 원칙

개인정보보호법 주요원칙 (법률 제3조)

항목	세부내용
처리목적의 명확화 원칙	개인정보처리자는 수집 당시에 개인정보의 처리 목적을 명확하게 특정하여야 한다.
최소 수집의 원칙	개인정보처리자는 처리 목적에 필요한 범위에서 최소한의 개인정보만을 수집하여야 한다.
적법한 수집 원칙	개인정보처리자는 개인정보를 적법하고 정당하게 수집하여야 한다.
목적외 이용금지 원칙	개인정보처리자는 처리목적에 직접적으로 필요한 범위 내에서 적합하게 개인정보를 처리하여야 하며 그 목적 외의 용도로 활용하지 않아야 한다.
정확성의 원칙	개인정보처리자는 개인정보의 처리 목적에 필요한 범위에서 개인정보의 정확성, 완전성 및 최신성이 보장되도록 하여야 한다.
안전성의 원칙	개인정보처리자는 개인정보의 처리 방법 및 종류 등에 따라 정보주체의 권리가 침해받을 가능성과 그 위험 정도를 고려하여 그에 상응하는 적절한 관리적·기술적 및 물리적 보호조치를 통하여 개인정보를 안전하게 관리하여야 한다.
공개성의 원칙	(개정) 개인정보처리자는 개인정보 처리방침 등 개인정보의 처리에 관한 사항을 공개하여야 하며, 열람청구권 등 정보주체의 권리를 보장하여야 한다.
정보주체 권리 존중의 원칙	개인정보처리자는 열람청구권, 정정·삭제요구권, 처리정지요구권 등 정보주체의 권리를 보장하여야 한다.
사생활 침해 최소화 원칙	개인정보처리자의 정보주체의 사생활 침해를 최소화하는 방법으로 개인정보를 처리하여야 한다.
익명/가명처리원칙	개인정보처리자는 개인정보를 익명 또는 가명으로 처리하여도 개인정보 수집목적 달성을 할 수 있는 경우 익명처리가 가능한 경우에는 익명에 의하여, 익명처리로 목적을 달성할 수 없는 경우에는 가명에 의하여 처리될 수 있도록 하여야 한다. <개정 2020. 2. 4.>
책임의 원칙	개인정보처리자는 「개인정보보호법」 등 개인정보 보호 관련 법령(이하 “개인정보보호법등”이라 한다)에서 규정하고 있는 책임과 의무를 준수하고 실천함으로써 정보주체의 신뢰를 얻기 위하여 노력하여야 한다.

개인정보보호법제 - 판례/결정례 등

개인정보 침해와 처벌

“ 법의 실효성 확보를 위해 일반적으로 다음과 같은 벌칙과 민사책임에 관한 사항을 두고 있음 ”

형사제재

징역형 또는 벌금, 몰수/추징

행정제재

과징금, 과태료

민사제재

법적·징벌적 손해배상

- ✓ 그 외에 분쟁조정(집단분쟁조정 포함)과 단체소송 규정
- ✓ 헌법 제111조 및 헌법재판소법 제47조, 제68조에 따른 위헌법률심판, 헌법소원 심판 청구 가능

개인정보보호법제 - 판례/결정례 등

개인정보 침해와 처벌

과태료
또는 과징금

실태점검결과, 법률위반 개인정보처리자에게 과태료부과, 시정명령, 개선권고 등 **행정제재**

분쟁조정/
집단분쟁조정

- 개인정보에 관한 분쟁이 발생시,비용이 많이 들고 시간이 오래 걸리는 **소송제도의 대안**
- **“재판상 화해”**(민사소송법상 **확정판결과 동일한 효력**) 부여

법정/징벌적
손해배상

정보주체가 개인정보처리자의 법위반 행위로 손해를 입으면 개인정보처리자에게 손해배상 청구가능
(법정손배: 300만원 이하, 징벌적손배: 손해액 3배 이내)

형사처벌

- 개인정보보호법이 정한 주요 내용에 대한 법
- 위반시 (10년 이하의 징역 또는 1억원 이하의 벌금~2년 이하 징역 또는 2천만원 이하의 벌금)

개인정보보호법
위반에 따른
개인정보처리자의
책임유형

※위법한개인정보처리의
정지/금지를 위한 단체소송은
논외로 함

※공공기관내부 규정에 의한
처벌은 논외로 함

사례로 살펴보는 개인정보 처리

개인정보 유형별 부적정 열람 예시

유형	유형별 예시
호기심	▪ 내부직원(전/현직)의 고용정보, 산재처리내역 열람 ▪ 대학동기의 급여가 궁금하여 고용정보 열람 ▪ 인턴직원 등 기간제직원이 입사 희망하는 기업의 급여 확인을 위한 고용정보 열람
제3자 요청	▪ 동료직원의 요청에 의해 타인의 개인정보 열람 ▪ 구직중인 사촌동생이 ○○기업의 급여를 문의하여 보수총액 열람 ▪ 민원서류 결재완료 전 지인의 부탁으로 장해등급 등 개인정보 열람
사적 목적	▪ 개인적인 채권·채무 관계로 채무자의 주소지 열람 ▪ 부동산 취득을 위해 경·공매 재산내역 열람
내부 행정업무	▪ 지사서무가 신규 전입자의 생일 확인을 위해 고용정보 열람 ▪ 연말정산 서류 작성을 위해 노동보험(고용정보) 열람 등

사례로 살펴보는 개인정보 처리

개인정보 목적외 이용에 따른 징계

가중 처벌 기준

- 목적외 이용에 따른 해당 징계에서 비위사항이 추가될 때마다 한 단계 상향 조정하여 가중 처벌

비위정도 개인정보 구분	비위사항이 1개인 경우	비위사항이 2개인 경우	비위사항이 3개인 경우
민감정보	강등	해임	파면
중요·고유식별정보	감봉	정직	강등
일반개인정보	견책	감봉	정직

가중 처벌 기준

비위정도 개인정보 구분	목적외 이용한 경우		목적외 이용 비위사항 1개		목적외 이용 비위사항 2개		목적외 이용 비위사항 3개
	불인정	인정	불인정	인정	불인정	인정	
민감정보	정직	감봉	강등	정직	해임	강등	파면
중요·고유식별정보	견책	경고	감봉	견책	정직	감봉	강등
일반개인정보	경고	주의	견책	경고	감봉	견책	정직

사례로 살펴보는 개인정보 처리

개인정보 유형별 부적정 열람 예시

유형	유형별 예시
유사사례	- 호흡기계질환 취소사례를 분석하면서 간암 승인상병자 열람 - 시설장의 근로자성 여부를 알아보기 위해 소속 기관장 고용정보 열람 - 타 기관 노동조합 전임자의 근로자성 여부를 확인 차 공단 노동조합 전임자 고용정보 열람
과도한 열람	- 심사청구서 처리 시 재해자 외 청구인(신청인) 산재처리내역 열람 - 가입서비스요원 퇴사처리 확인을 위해 고용정보검색 화면에서 공단 관리번호 입력 후 전체 조회
프로그램 개발	신규/수정된 프로그램 사용자 테스트를 위해 제3자의 개인정보 열람
교육용 열람	신규 직원(상담사) 교육을 위해 제3자의 개인정보 열람
사전동의 미비	정보주체의 동의가 필요한 경우임에도 불구하고 동의를 받지 않고 열람하는 경우 등

사례로 살펴보는 개인정보 처리

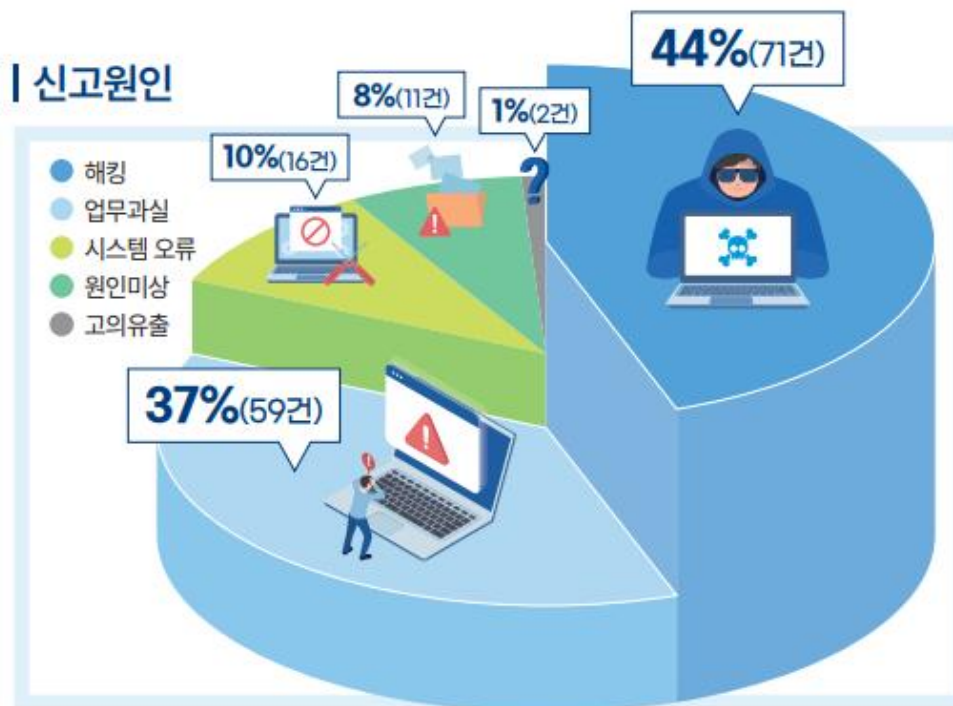
개인정보 유출 신고 현황

2024년도 상반기(1~6월)
개인정보 유출신고는 총 159건

| 신고건수



| 신고원인



* 전년도 상반기 대비 20% 감소(2023년 198건 → 2024년 159건)

사례로 살펴보는 개인정보 처리

개인정보 사고사례 분석

대상	사고개요	사고원인
코웨이	<u>내부직원 198만명</u> 개인정보 유출(경쟁사 유입)	내부직원 유출
국민연금	기금운영 대외비 자료 유출(자산운용 회사 유입)	내부직원 유출
카페베네	홈페이지 해킹, 변조, <u>저작권 법</u> 위반(본사,직영매장 MS Windows / Office 불법사용) 3~5억 피소	외부 해킹, 법 위반
삼성카드 SK 하나카드	<u>마케팅 직원</u> 에 의한 개인정보 유출	내부직원 유출
KT	개인정보 유출 KT 주식 5% 급락 <u>과징금 7억 5천 부과</u>	대리점/위탁사 /협력업체
조선일보	전산망 해킹(실패), 이메일 해킹 공격	기술적 공격
한국전력기술	<u>퇴직자 2명</u> 의 의해 중요 설계자료 유출	내부직원 유출
한화손해보험	자동차 보험 출동직원 해킹, 15만 개인정보 유출, <u>16개월간 미신고 및 은폐</u>	외부 해킹
메리츠화재	<u>내부직원</u> 에 의한 <u>16만 개인정보 유출(판매)</u>	내부직원 유출
주요 정부 언론기관	청와대 홈페이지 및 주요 정부기관 사이버공격	외부 해킹
인터넷 나야나	웹 서비스 <u>서버 데이터의 랜섬웨어 암호화</u> : 해커와 30억 협상 ※ 협상이 가능했던 이유 : 기업문화 및 상황(정보)을 전부 알고 있음	외부 해킹
블랙야크	<u>직원 PC 모니터 및 스캠</u> 으로 60억원 해커에게 이체(증발)	외부 해킹
위메프	개인정보 20건 유출 : <u>18억 5천 200만원 과징금</u>	내부직원 유출

사례로 살펴보는 개인정보 처리

개인정보 유출 판례 - 인터파크



- ✓ 2016년 인터파크 시스템 해킹으로 정보주체 1,030만명의 개인정보 2,540만건 유출 (이름/성별/전화번호 등)
- ✓ 행정소송에 불구, 1,2심 패소 및 대법원 최종판결

최종 판결(2020) : 과징금 46억, 정보주체 1인당(2400명) 10만원씩 배상 판결



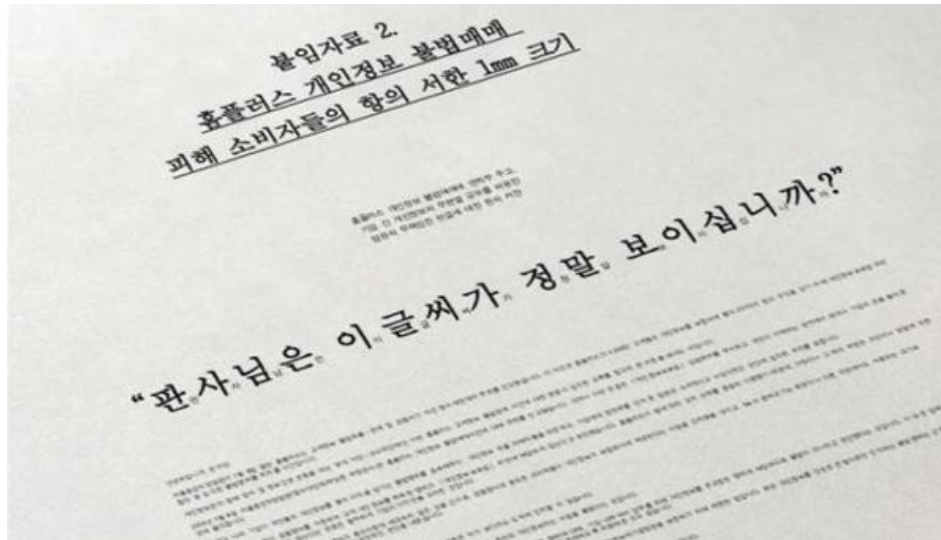
처분사유(개인정보 안전성 확보조치 미흡)

1. 최대 접속시간 제한 등의 기술적 안전조치 : **화면보호기 미적용**
 2. 망분리 : 보안성이 떨어지는 가상화 방식 적용하여 운영한 행위
 3. 백업파일 관리 : 개인정보처리시스템으로 백업한 이용자의 개인정보 미암호화 및 분리보관 미실시
 4. 원격데스크톱 설정 PC에 **RDP 방식 공유설정 허용**
 5. 접속기록 : 공휴일, 연휴 이후 접속기록 재분석 및 CISO 보고 등 보안관제 소홀
 6. DB서버 웹서버 등 ID/PW 관리 소홀 : 비밀번호 평문 기록으로 텍스트 파일로 PC에 저장
 8. NAS(파일) 서버 : 사내 전산장비, 정보자산의 IP, PW 등이 기록된 엑셀파일과 파일 내 비밀번호를 텍스트 파일 형태로 평문 기록하여 저장
 9. 정당한 사유 없이 개인정보 유출사실(이용자 통지 및 신고)을 지연한 행위
- ※ 감경 : "정보보호 관리체계 인증(ISMS-P)"을 받음으로 과징금이 경감

⚠ 주의! 법률근거가 없더라도 '사회통념상' 누구나 합리적으로 예상 할 수 있는 안전조치는 되도록 조치해야 함

사례로 살펴보는 개인정보 처리

개인정보 유출 판례 - 홈플러스



최종 판결(2019)

- 대표이사 도성환 및 임직원 5명 징역 6개월 ~ 2년(집행유예)
- 과태료 및 과징금 : 총 약 1억

“판사님은 이 글씨가 정말 보이십니까?” – 홈플러스의 깨알고지(1mm) 사건

- ✓ 개인정보 동의서 글씨를 작게하여 정보주체로부터 '경품행사를 가장한 **부정한 수단과 방법으로** 정보 취득하고 보험사에 **개인정보 판매**(제3자제공)...'



2023년, “경제벌”로 전환

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 골프존

✓ 안전조치의무 위반

개인정보보호위원회

보도자료

2024. 5. 9.(목) 12:00 배포 2024. 5. 8.(수) 18:00

개인정보위, (주)골프존 개인정보 유출사고에 대해 과징금 75억 원, 과태료 540만 원 및 시정명령 부과

개인정보보호위원회(위원장 고학수, 이하 '개인정보위')는 5월 8일(수) 제8회 전체회의를 열고, 개인정보보호 법규를 위반한 (주)골프존에 대해 총 75억 4백만 원의 과징금과 540만 원의 과태료를 부과하고, 동시에 시정명령 및 공표명령을 의결하였다.

(주)골프존은 지난해 11월 해커에 의한 랜섬웨어 공격을 받았고, 이 과정에서 해커는 알 수 없는 방법으로 (주)골프존 직원들의 가상사설망 계정정보를 탈취하여 업무망 내 파일서버에 원격접속('23.11.22.)하고 파일서버에 저장된 파일을 외부로 유출('23.11.22.~23.)한 후 다크웹에 공개하였다.

* 이 계정 중에는 서버 관리자 계정도 포함됨
 ** 윈도우의 공유폴더 기능을 이용, 임직원들의 PC에 파일서버의 폴더가 생성·공유

이로 인해 업무망 내 파일서버에 보관되어 있던 약 221만명 이상의 서비스 이용자 및 임직원의 개인정보(이름, 전화번호, 이메일, 생년월일, 아이디 등)가 유출되었고, 일부의 경우 주민등록번호(5,831명)와 계좌번호(1,647명)도 유출되었다.

개인정보위가 이번 유출사고에 대한 (주)골프존의 개인정보 보호법 준수 여부를 조사한 결과, 확인된 주요 위반사항은 다음과 같다.

< 안전조치의무 위반 >

먼저, (주)골프존은 전 직원이 사용하는 파일서버에 주민등록번호를 포함한 다량의 개인정보가 저장되어 공유되고 있다는 사실을 인지하지 못했고, 개인

Point 1

먼저, (주)골프존은 전 직원이 사용하는 파일서버에 주민등록번호를 포함한 다량의 개인정보가 저장되어 공유되고 있다는 사실을 인지하지 못했고...



개인정보 안전성 확보조치(고시 2023. 9. 22)

[제4조] (내부 관리계획의 수립·시행 및 점검)

④ 개인정보 보호책임자는 접근 권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 내부 관리계획의 이행 실태를 연1회 이상 점검·관리 하여야 한다.

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 골프존

정보파일이 보관되어있는 파일서버에 대한 주기적 점검 등 관리체계를 미흡하게 운영한 것으로 밝혀졌다.

구체적으로, 코로나19로 재택근무가 급증하자 (주)골프존은 새로운 가상사설망을 긴급히 도입하는 과정에서 외부에서 내부 업무망에 ID와 PW만으로 접속할 수 있도록 허용하였음에도, 업무망 안에 존재하는 파일서버에 대해 개인정보 유출 관련 보안위험을 검토하고 필요한 안전조치를 하지 않았다.

이로 인해 외부에서 서버로의 원격접속 등 불필요한 접근이 허용되었고, 서버 간의 원격접속과 업무망 내 모든 서버의 인터넷 통신이 허용되는 등 공유설정을 통한 개인정보 유출을 방지하기 위한 안전조치가 소홀하였다.

이에 해커는 탈취한 서버 관리자 계정으로 가상사설망을 통해 파일서버에 접근하고 파일서버에서 외부로 파일을 유출할 수 있었다.

< 주민등록번호 처리제한 및 개인정보 파기 위반 >

또한, 주민등록번호 등을 암호화하지 않고 파일서버에 저장·보관하고 있었고, 보유기간이 경과되거나, 처리목적 달성 등 불필요하게 된 최소 38만여명*의 개인정보를 파기하지 않은 위반행위가 있었다.

* △ 조회원 중 현재 회원으로 확인되지 않은 383,365명의 정보, △ 임직원 정보 중 퇴사하여 보유 근거가 없는 2,916명의 정보, △ 인턴사원 및 전문연구요원 1,159명의 채용관련 정보, △ 기타 고객응대(VOC) 관련 이용자 및 점주의 개인정보 등

개인정보위는 (주)골프존에 대해 보호법 제29조 안전조치의무 위반으로 과징금을 부과하고, 같은 법 제21조 개인정보 파기의무를 준수하지 않은 행위에 대해 과태료 부과를 결정하였다.

Point 2

구체적으로, 코로나19로 재택근무가 급증하자 (주)골프존은 새로운 가상사설망을 긴급히 도입하는 과정에서 외부에서 내부 업무망에 ID와 PW만으로 접속할 수 있도록 허용하였음에도, 업무망 안에 존재하는 파일서버에 대해 개인정보 유출 관련 보안위험을 검토하고 필요한 안전조치를 하지 않았다.

이로 인해 외부에서 서버로의 원격접속 등 불필요한 접근이 허용되었고, 서버 간의 원격접속과 업무망 내 모든 서버의 인터넷 통신이 허용되는 등 공유설정을 통한 개인정보 유출을 방지하기 위한 안전조치가 소홀하였다.

개인정보 안전성 확보조치(고시 2023. 9. 22)

[제2조] 이 기준에서 사용하는 용어의 뜻은 다음과 같다

6. "공유설정"이란 컴퓨터 소유자의 파일을 타인이 조회·변경·복사 등을 할 수 있도록 설정하는 것을 말한다.

[제6조] (접근통제)

③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다.

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례

참고 : 개인정보의 안전성 확보조치 기준 안내서(2024.10.)

- 개인정보처리자는 개인정보처리시스템, 개인정보취급자의 컴퓨터, 모바일 기기 등에 P2P, 공유설정은 기본적으로 사용하지 않는 것이 원칙이나, 업무상 반드시 필요한 경우에는 권한 설정 등의 조치를 통해 정당한 권한이 있는 자만 접근할 수 있도록 설정하여 개인정보가 권한이 없는 자에게 공개되거나 유출되지 않도록 접근통제 등에 관한 안전조치를 하여야 한다.
 - 업무상 꼭 필요한 경우라도 드라이브 전체 또는 불필요한 폴더가 공유되지 않도록 조치하고, 공개 설정된 공유폴더에 개인정보 파일이 포함되지 않도록 정기적인 점검이 필요하다.
 - 원격접속 프로그램을 통해 개인정보취급자 컴퓨터 등에 접속하는 경우도 공유설정에 해당되므로, 정당한 권한이 있는 자만이 접근할 수 있도록 접근통제 조치를 적용하여야 한다.
 - 이 외에도 외부 웹메일, 웹하드, 메신저, 클라우드 저장소, SNS 서비스 등을 통하여 고의 혹은 부주의로 인한 개인정보의 유·노출이 발생하지 않도록 접근통제 등을 해야 한다.

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 골프존

정보파일이 보관되어있는 파일서버에 대한 주기적 점검 등 관리체계를 미흡하게 운영한 것으로 밝혀졌다.

구체적으로, 코로나19로 재택근무가 급증하자 ㈜골프존은 새로운 가상사설망을 긴급히 도입하는 과정에서 외부에서 내부 업무망에 ID와 PW만으로 접속할 수 있도록 허용하였음에도, 업무망 안에 존재하는 파일서버에 대해 개인정보 유출 관련 보안위험을 검토하고 필요한 안전조치를 하지 않았다.

이로 인해 외부에서 서버로의 원격접속 등 불필요한 접근이 허용되었고, 서버 간의 원격접속과 업무망 내 모든 서버의 인터넷 통신이 허용되는 등 공유설정을 통한 개인정보 유출을 방지하기 위한 안전조치가 소홀하였다.

이에 해커는 탈취한 서버 관리자 계정으로 가상사설망을 통해 파일서버에 접근하고 파일서버에서 외부로 파일을 유출할 수 있었다.

<주민등록번호 처리제한 및 개인정보 파기 위반>

또한, 주민등록번호 등을 암호화하지 않고 파일서버에 저장·보관하고 있었고, 보유기간이 경과되거나, 처리목적 달성 등 불필요하게 된 최소 38만여명*의 개인정보를 파기하지 않은 위반행위가 있었다.

* ▲ 준회원 중 현재 회원으로 확인되지 않은 383,365명의 정보, ▲ 임직원 정보 중 퇴사하여 보유 근거가 없는 2,916명의 정보, ▲ 인턴사원 및 전문연구요원 1,159명의 채용관련 정보, ▲ 기타 고객응대(VOC) 관련 이용자 및 점주의 개인정보 등

개인정보위는 ㈜골프존에 대해 보호법 제29조 안전조치의무 위반으로 과징금을 부과하고, 같은 법 제21조 개인정보 파기의무를 준수하지 않은 행위에 대해 과태료 부과를 결정하였다.

또한 ▲ 회사 내의 개인정보 처리흐름에 대한 면밀한 분석을 통한 실질적인 내부관리계획 수립·시행, ▲ 공유설정 등을 통해 개인정보가 유출되지 않도록 조치하는 등 안전조치의무 준수, ▲ 개인정보보호책임자의 위상과 역할 강화, ▲ 전 직원 대상 개인정보 보호 교육을 주기적으로 실시할 것을 시정명령한 동시에, 이러한 사실을 홈페이지 등에 공표하도록 명령하였다.

Point 3

<주민등록번호 처리제한 및 개인정보 파기 위반>

또한, 주민등록번호 등을 암호화하지 않고 파일서버에 저장·보관하고 있었고, 보유기간이 경과되거나, 처리목적 달성 등 불필요하게 된 최소 38만여명*의 개인정보를 파기하지 않은 위반행위가 있었다.

* ▲ 준회원 중 현재 회원으로 확인되지 않은 383,365명의 정보, ▲ 임직원 정보 중 퇴사하여 보유 근거가 없는 2,916명의 정보, ▲ 인턴사원 및 전문연구요원 1,159명의 채용관련 정보, ▲ 기타 고객응대(VOC) 관련 이용자 및 점주의 개인정보 등

개인정보 안전성 확보조치(고시 2023. 9. 22)

[제7조] (개인정보의 암호화)

② 개인정보처리자는 다음 각 호의 해당하는 이용자의 개인정보에 대해서는 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.

1. 주민등록번호

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 구글과 메타



구글(GoogleLLC)은 최소 약 6년간(16.6~현재) 자사 서비스에 가입한 이용자의 타사 행태정보를 수집하여 맞춤형 광고 등에 이용하면서, **그 사실을 해당 이용자에게 명확하게 알리고 동의를 받지 않음**

그러면서, **타사 행태정보 수집 사실을 명확히 알리지 않고, 그 설정 화면(옵션 더보기)을 가려둔 채 기본값을 '동의'로 설정**

<구글의 '옵션 더보기' 화면 >

옵션 더보기 ^

개인 설정 및 계정에 저장된 데이터를 확인하여 Google 사용 환경을 맞춤설정하세요.

Google 계정(account.google.com)에서 언제든지 이러한 옵션에 대해 자세히 알아보고, 옵션을 조정하고, 내 활동을 검토할 수 있습니다.

🔗 웹 및 앱 활동

Google 사이트 및 앱에서 이루어진 활동(예: 검색)과 관련 정보(예: 위치)를 저장합니다. Chrome 방문 기록을 비롯한 Google 서비스를 사용하는 사이트, 앱, 기기에서 이루어진 활동도 저장합니다. 이렇게 하면 여러 Google 서비스에서 더욱 유용한 검색결과, 추천, 맞춤 설정 기능을 제공하는 데 도움이 됩니다. 18개월이 지난 활동은 자동으로 삭제됩니다. account.google.com에서 자동 삭제 옵션을 변경하고 활동 저장을 중단하거나 활동을 직접 삭제할 수 있습니다.

☒ Google 계정에 웹 및 앱 활동 저장

☐ Google 계정에 웹 및 앱 활동을 저장하지 않음

[자세히 알아보기](#)

☐ 광고 개인 최적화

Google에서 검색, YouTube 등의 Google 서비스 및 Google과 파트너 관계를 맺은 웹사이트 및 앱에서 이루어진 내 활동을 바탕으로 광고를 표시할 수 있습니다.

☒ 개인 맞춤 광고 표시

☐ 맞춤설정되지 않은 광고 표시

[자세히 알아보기](#)

📺 YouTube 기록

나의 YouTube 동영상 시청 기록과 YouTube에서의 검색 기록이 저장됩니다. 이렇게 하면 Google에서 나에게 더 적합한 항목을 추천하고, 내가 시청을 중단한 시점을 기억하는 등 나의 사용 환경을 개선하는 데 도움이 됩니다. 36개월이 지난 활동은 자동으로 삭제됩니다. account.google.com에서 자동 삭제 옵션을 변경하고 활동 저장을 중단하거나 활동을 직접 삭제할 수 있습니다.

☒ Google 계정에 YouTube 기록 저장

☐ Google 계정에 YouTube 기록을 저장하지 않음

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 구글과 메타



- 이용자의 타사 행태정보를 수집하여 맞춤형 광고 등에 이용 하면서, 그 사실을 해당 이용자에게 명확하게 알리고 동의를 받지 않음
- 페이스북은 계정 생성 시 한 번에 다섯 줄밖에 보이지 않는 스크롤 화면에 행태정보 수집 관련 사항("파트너가 제공하는 정보")이 포함된 데이터 정책 전문(694줄)을 게재한 것 외에 별도로 법정 고지사항을 알리고 동의받지 않음
- 인스타그램 계정을 생성하는 과정에서는 "이용 약관에 동의" 화면에서 "데이터 정책(필수)"을 선택하도록 하면서 "더 알아보기"를 누르는 경우 "Instagram 데이터 정책" 전문을 보여주고 있음

<페이스북 가입 시 "데이터 정책" 스크롤 화면에서 나타나는 화면>

가입하기
빠르고 쉽습니다.

이용 약관 및 개인정보처리방침에 동의하셔야 합니다.

보안 확인
로봇이 아닙니다. reCAPTCHA 개인정보 보호 - 약관

이 내용이 표시되는 이유는?

파트너가 제공하는 정보.
광고주, 앱 개발자 및 퍼블리셔는 이들이 사용하는 Meta 비즈니스 도구, 즉 당사의 소셜 플러그인(예: '좋아요' 버튼), Facebook 로그인, 당사 API와 SDK 또

☐ Facebook의 데이터 정책에 동의합니다

공백포함 14,600여 개 글자, 694줄

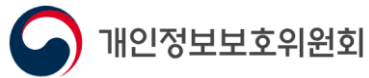
로그인

새 계정 만들기

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 구글과 메타

시정조치 및 행정소송



● 시정명령 및 과징금 부과

- '22년 9월에 구글과 메타가 이용자 동의 없이 다양한 온라인 활동 기록*을 수집해 맞춤형 광고에 활용한 사실에 대한 시정명령과 함께 과징금 약 1,000억 원(구글 692억, 메타 308억)을 부과

VS



● 행정소송 제기(행정처분 취소)

- '23년 2월 서울행정법원에 소송을 제기

구글과 메타의 주장

- ✓ 구글과 메타는 "웹사이트 또는 앱을 운영하는 사업자가 개인 정보 수집 주체로서 이용자의 동의를 받아야 하며, 설령 구글과 메타가 이용자 동의를 받아야 한다고 해도 개인정보 처리방침 등을 통해 알리고 동의를 받았다"고 주장

✓ 25.1.23 최종판결 : 구글 메타의 주장은 모두 기각되어, 개인정보보호위원회 승소

이
유

1. 구글과 메타는 개인정보 보호법에 따라 개인정보에 해당하는 정보의 수집과 이용 동의를 받아야 할 의무가 있다고 판단
2. 개인정보를 수집한다는 점에 대한 설명이 제대로 없고 이런 조치만으로 개인정보 수집에 대한 동의를 받은 것으로 볼 수 없다
3. 개인정보 수집 방식이 기술적으로 복잡하고 은밀하게 이뤄져 이용자들이 이를 인지하기 쉽지 않아 서비스 이용자로서는 자신의 온라인 활동이 누군가에게 감시당하는 것이 아닌지 불안감을 느낄 가능성이 있다
4. 피고가 재량권을 일탈하거나 남용했다고 보지 않았다

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 구글과 메타



개인정보처리방침은 동의서일까?

구분	개인정보 처리방침	개인정보 수집·이용 동의서
법적 성격	안내문	동의서(법적 효력)
법적 효력	동의서로서 효력 없음	동의받은 범위 내에서만 효력 발생
목적	처리 절차, 기준 안내	개인정보 수집·이용 동의
방식	단순 고지	명확한 구분, 자발적 동의 필요

사례로 살펴보는 개인정보 처리

 개인정보 유출 심의 의결사례 - 구글과 메타



행태정보는 '개인정보'일까?

구분	동의 필요 여부	주요 준수사항 및 주의점
식별 불가 행태정보	동의 불필요(조건부*) * 조건부 : 식별 가능성	■ 비식별화 유지 ■ 결합·매핑 금지 ■ 투명성 확보 등
식별 가능한 행태정보	동의 필수(개인정보)	■ 식별 가능성 판단 ■ 명확한 고지 및 동의

※ 참고사항 : 2025년 중 행태정보에 관한 가이드 발표 예정

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례-크리덴셜 스테핑

■ 사건개요

DIGIT@L ESUNG

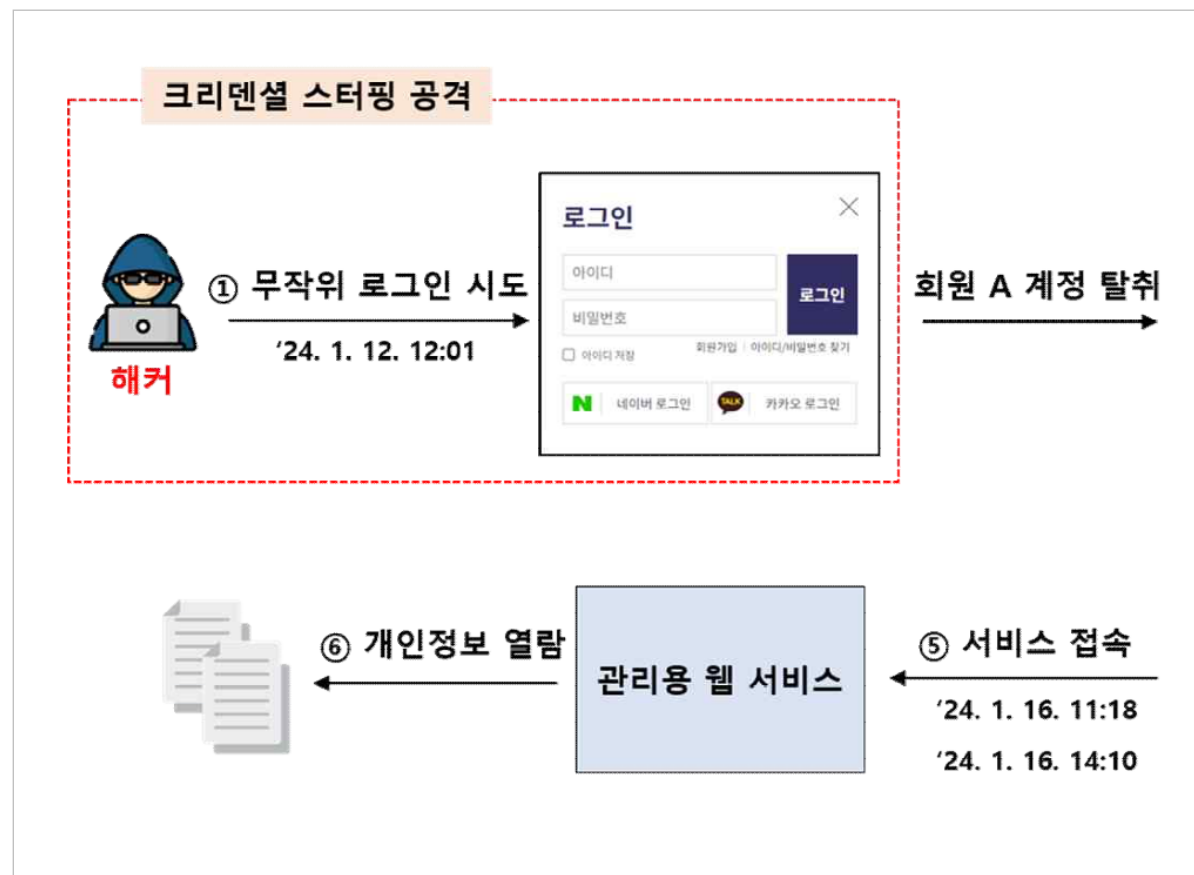
문제점 1

- 해커의 '크리덴셜 스테핑*(Credential Stuffing)' 공격과 누리집 내 게시판에 대한 '크로스사이트 스크립팅(XSS, Cross-Site Scripting)' 공격으로 회원 95,000여명의 개인정보가 유출

* 이미 확보한 아이디, 비밀번호를 다른 누리집에도 무작위로 대입하여 로그인 정보를 확인하는 공격 기법

※ 해커들이 다크웹에 상당히 많은 해킹 된 정보를 공개 중으로 사회적 위협이 커지고 있음

< 개인정보 유출 경위 >



사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 크리덴셜 스테핑

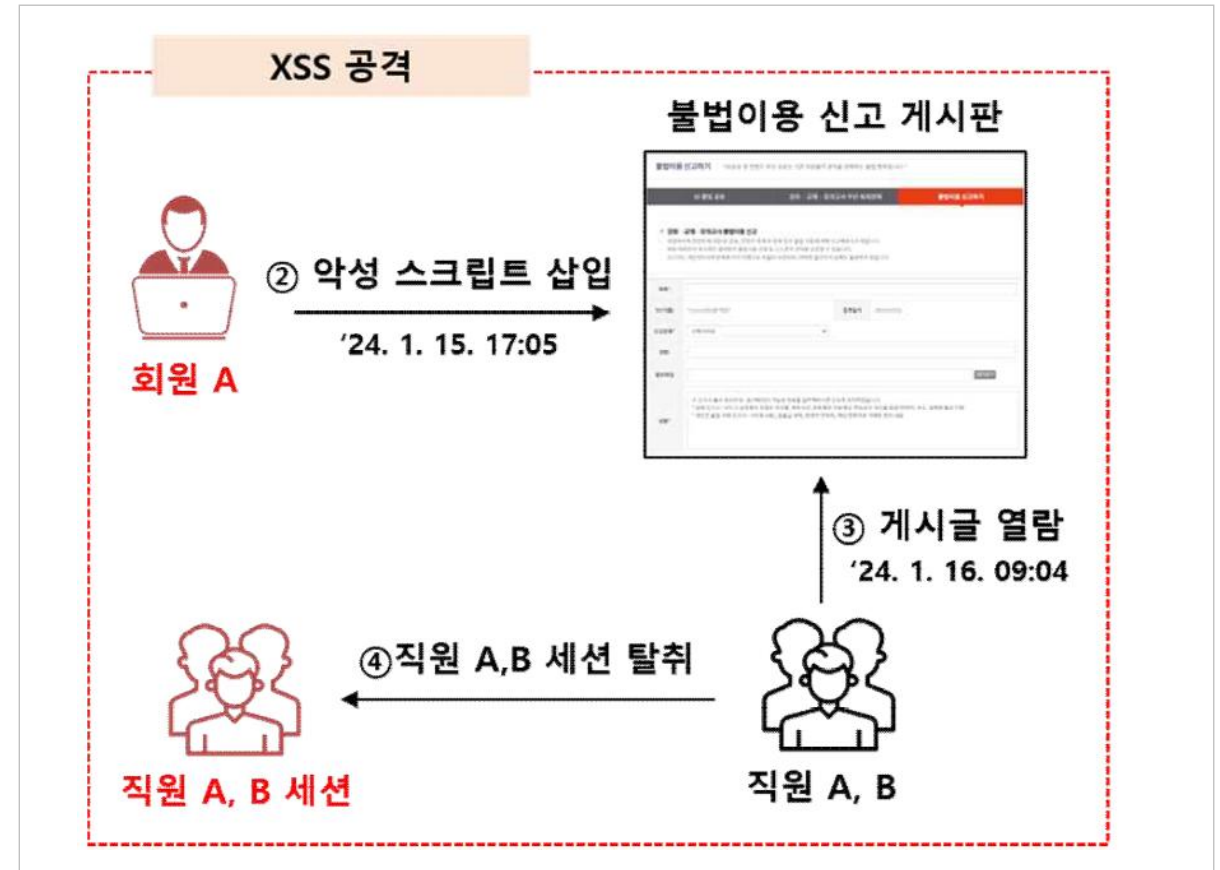
■ 사건개요

DIGIT@L ESUNG

문제점 2

- 일부 페이지에 대한 취약점 점검을 누락하여 게시판에 악성 스크립트가 삽입
- 유출 인지 후 72시간을 경과하여 유출통지를 완료

< 개인정보 유출 경위 >



사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 크리덴셜 스테핑

■ 위반사항

**DIGIT@L
D@ESUNG**

- ✓ 「개인정보 보호법」 제29조의 안전조치 의무
- ✓ 「개인정보 보호법」 제34조제1항의 유출통지 의무

- 과징금 6억 1,300만 원
- 과태료 330만 원
- 공표명령*

* 공표명령이란?

개인정보 보호법 개정(23.9.15.)으로 신설된 처분 규정으로, 사업자 홈페이지 또는 일간지 등에 과징금과태료 등의 처분받은 사실을 공표하는 제도

< 개인정보 유출사고 안내 및 사과문 >

개인정보 유출사고에 대한 안내 및 사과

(주)디지털대성은 다음과 같이 개인정보 침해 사실을 알려드립니다.

먼저 당사는 매년 정보보호 관리체계(ISMS) 인증 획득 및 갱신 등의 노력으로 회원님들의 개인정보보호를 위해 최선의 노력을 다해왔으나 이번 유출 사고로 회원님들의 심려를 끼치게 되어 진심으로 사과 말씀드립니다.

2024년 1월 16일(화) 외부 해킹에 의하여 일부 회원들의 개인정보 95,170건이 유출되었고 침해 사실을 보안 모니터링을 통해 즉시 발견 하였습니다.

침해 사실 인지 후 곧바로 한국인터넷진흥원(KISA) 및 관련 수사기관에 신고 하였으며, 해킹 의심 IP와 침투 경로를 모두 차단하고 취약점 점검 및 보완 조치를 진행하여 재발 방지를 위한 대응을 강화하고 있습니다.

유출된 항목은 개인별로 차이가 있지만 'ID, 마스킹 된 이름, 마스킹 된 이메일, 마스킹 된 휴대폰번호' 총 4개 항목으로 이름/이메일/휴대폰번호는 주요정보가 가려진 상태로 개인을 식별하기 어렵습니다. (이름(홍*동), 휴대폰번호(010-****-1234), 이메일(ab*****@abc.com))

[내 개인정보 유출 여부 확인하기 >](#)

사례로 살펴보는 개인정보 처리

개인정보 유출 심의 의결사례 - 크리덴셜 스테핑

크리덴셜 스테핑, 어떻게 해야 할까?

다중 인증(MFA, 2단계 인증) 활성화 : ID/PW 방식 외에
추가 인증수단(문자, 생체인증, CAPTCHA, OTP 등) 적용

IDLess 방식 적용 :
소유기반의 핸드폰
본인인증만으로 서비스 제공

인증서 로그인 방식
활용(공동인증서 등)

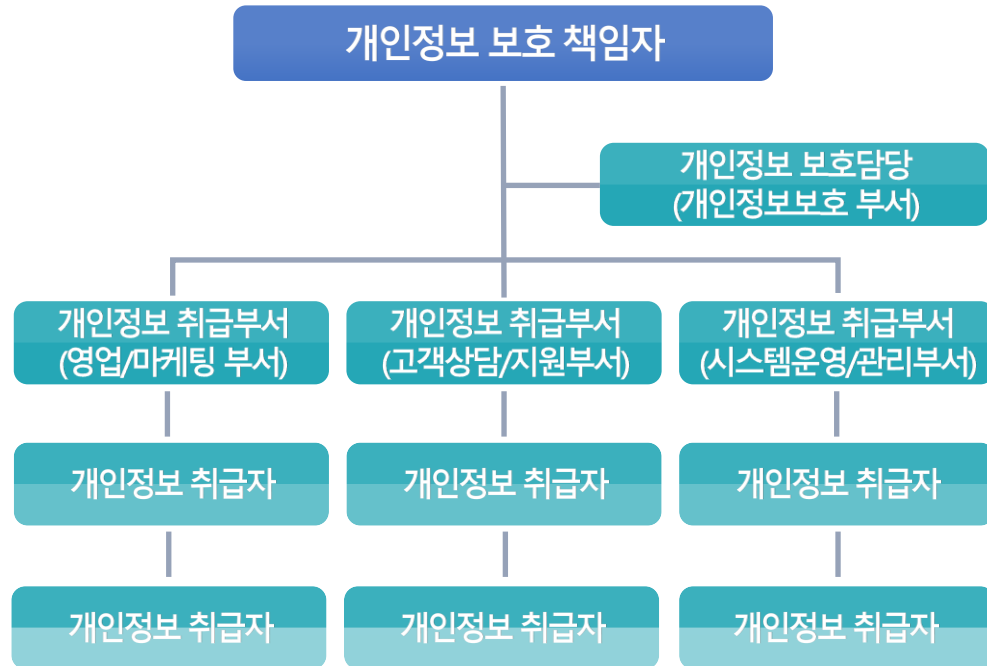


비정상 로그인 탐지 및 알림

사례로 살펴보는 개인정보 안전관리 등

개인정보처리자 기준 관리체계

[개인정보 보호조직 구성도 예시]



✓ 개인정보 보호책임자

- 개인정보 처리에 관한 업무를 총괄해서 책임지는 자

✓ 개인정보 보호담당

- 개인정보 보호책임자의 지휘감독 하에 개인정보 보호책임자의 업무를 지원하는 자

✓ 개인정보 취급부서

- 개인정보를 처리하는 부서

✓ 개인정보 취급자

- 개인정보처리자의 지휘감독을 받아 개인정보를 처리하는 업무를 담당하는 자

사례로 살펴보는 개인정보 안전관리 등

개인정보보호조직의 구성 및 역할

“ 효율적이고 책임 있는 개인정보 보호 체계 형성과 운영을 위해
업무 담당자, 담당업무, 책임을 명시할 필요가 있음 ”

✓ 조직 구성 및 담당자 지정

- 개인정보 보호책임자 및 분야별 담당자, 개인정보취급자 등의 조직 구성 및 담당업무 지정
- 개인정보보호법 제31조, 법 제28조에 규정된 담당업무 준수

✓ 개인정보책임자 및 역할 안내

- 개인정보처리방침을 통해 개인정보보호책임자 및 개인정보 보호 담당부서 연락처 등 안내
- 분야별 책임자 및 개인정보취급자(직원 등)이 숙지할 수 있도록 내부 게시판과 안내문 등을 통해 준수사항 안내

사례로 살펴보는 개인정보 안전관리 등

CPO vs. DPO

GDPR	개인정보보호법	비고
[제7조] - 컨트롤러는 개인정보처리의 목적과 수단을 결정하는 주체를 의미함 - 컨트롤러는 개인정보처리의 목적과 수단을 규정하기만 하면 족하며, 자신이 개인정보를 직접 수집하여 프로세서에게 제공할 필요는 없음	[제31조제1항] - 개인정보처리자는 개인정보의 처리에 관한 업무를 총괄해서 책임질 개인정보보호 책임자를 지정하여야 함 [시행령 제32조제2항] - 개인정보 처리자는 법 제31조제2항에 따라 개인정보 보호책임자를 지정하려는 경우에는 다음 각 호의 구분에 따라 지정함 - 공공기관 : 시행령 제32조 제2항 제1호 법정기준에 해당하는 공무원 등 - 공공기관 외의 개인정보처리자 : 다음의 어느 하나에 해당하는 사람 가. 기업주 또는 대표자 나. 임원(임원이 없는 경우에는 개인정보 처리 관련 업무를 담당하는 부서의 장)	- 국내법 상 개인정보보호책임자의 자격 요건은 공무원 또는 사업주, 대표자, 임원 등 일정 지위로 구분함 - GDPR은 전문적 자질, 특히 개인정보보호법과 실무에 대한 전문적 지식 및 제39조에 언급된 직무를 환수할 능력에 근거하여 지정되어야 하며, 독립된 지위가 보장됨

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치

[개인정보 보호법 시행령]

제30조 (개인정보의 안전성 확보 조치) ① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 하여야 한다.

1. 개인정보의 안전한 처리를 위한 내부 관리계획의 수립·시행
2. 개인정보에 대한 접근 통제 및 접근 권한의 제한 조치
3. 개인정보를 안전하게 저장·전송할 수 있는 암호화 기술의 적용 또는 이에 상응하는 조치
4. 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조·변조 방지를 위한 조치
5. 개인정보에 대한 보안프로그램의 설치 및 갱신
6. 개인정보의 안전한 보관을 위한 보관시설의 마련 또는 잠금장치의 설치 등 물리적 조치

② 보호위원회는 개인정보처리자가 제1항에 따른 안전성 확보 조치를 하도록 시스템을 구축하는 등 필요한 지원을 할 수 있다.

③ 제1항에 따른 안전성 확보 조치에 관한 세부 기준은 보호위원회가 정하여 고시한다.

✓ 개인정보의 안전성 확보조치 기준

[제1조] 이 기준은 개인정보처리자가 개인정보를 처리함에 있어서 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 **기술적·관리적 및 물리적 안전조치에 관한 최소한의 기준**

사례로 살펴보는 개인정보 안전관리 등

안전조치 의무

✓ 점검사항

내부관리계획 수립

- 개인정보 처리단계별 내부 관리 지침 수립
- 개인정보 처리방침 수립, 공개
- 개인정보 보호책임자 지정
- 개인정보 유출 통지

관리적/기술적/물리적 조치

- 주기적인 개인정보 보호 교육 실시
- 입출력 또는 저장된 개인정보와 저장매체 관리 및 보호
- 접근권한 부여 및 접근 사실 자동기록
- 개인정보 접근 인원 최소화
- 고유식별정보·비밀번호·바이오정보 등의 암호화
- 보안 프로그램 설치 및 운영
- 물리적 접근방지

✓ 영향평가

- 공공기관 : 의무
- 민간 : 적극적 권고

사례로 살펴보는 개인정보 안전관리 등

내부 관리계획수립

✓ 개인정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 다음의 사항을 포함하는 내부관리 계획을 수립·시행

- ① 개인정보 보호 조직의 구성 및 운영에 관한 사항
- ② 개인정보 보호책임자의 자격요건 및 지정에 관한 사항
- ③ 개인정보 보호책임자와 개인정보취급자의 역할 및 책임에 관한 사항
- ④ 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항
- ⑤ 접근 권한의 관리에 관한 사항
- ⑥ 접근 통제에 관한 사항
- ⑦ 개인정보의 암호화 조치에 관한 사항
- ⑧ 접속기록 보관 및 점검에 관한 사항
- ⑨ 악성프로그램 등 방지에 관한 사항
- ⑩ 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항
- ⑪ 물리적 안전조치에 관한 사항
- ⑫ 개인정보 유출사고 대응 계획 수립·시행에 관한 사항
- ⑬ 위험 분석 및 관리에 관한 사항
- ⑭ 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항
- ⑮ 개인정보 내부 관리계획의 수립, 변경 및 승인에 관한 사항
- ⑯ 그 밖에 개인정보 보호를 위하여 필요한 사항

사례로 살펴보는 개인정보 안전관리 등

내부 관리계획수립

- ✓ 1~16의 사항에 중요한 변경이 있는 경우에는 이를 즉시 반영하여 내부 관리계획을 수정하여 시행하고, 그 수정이력을 관리
- ✓ 개인정보 보호책임자는 연 1회 이상으로 내부 관리계획의 이행 실태를 점검·관리

내부관리계획 이행 실태 점검 의무

- ✓ 개인정보보호 내부관리계획제4조(내부관리계획의 수립·시행)
 - 개인정보 보호책임자는 접근권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 내부 관리계획의 이행 실태를 연 1회 이상으로 점검·관리 하여야 함
 - 개인정보 보호책임자는 **내부관리계획의 적정성과 실효성을 보장**하기 위하여 연 1회 이상 내부관리계획에 따른 접근권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 **기술적·관리적 및 물리적 안전조치의 이행 여부**를 **점검·관리**하여야 함

사례로 살펴보는 개인정보 안전관리 등

기술적·관리적 보호조치 이행 여부의 내부 점검에 관한 사항

✓ 내부관리계획의 적정성과 실효성 보장 위한 내부관리계획에 따른 기술적·관리적 및 물리적 보호조치의 이행 여부의 점검·관리에 관한 사항 포함

- “○○년 개인정보 보호조치 이행 점검 계획(안)” 등과 같은 형태로 수립할 수 있으며, 점검 대상, 점검 항목 및 방법 등을 포함하도록 함
- 이행 점검은 사내 독립성이 보장되는 부서(감사팀 등), 관련 부서(개인정보보호팀) 또는 개인정보보호 전문업체 수행 가능
- 이행 점검은 개인정보취급자가 적절하게 개인정보 보호조치를 이행하고 있는지 여부 등을 파악할 수 있도록 정기적(최소 연 1회 권고) 점검 의무
- 이행 점검 결과는 “○○년 개인정보 보호조치 이행 점검 결과” 등과 같은 형태로 작성할 수 있으며, 필요하면 사업주 또는 대표자에게 점검결과 및 개선조치 보고

이행 점검 (예시)

- ☞ 점검 대상 및 시기
- ☞ 점검 조직 및 인력
- ☞ 점검 항목 및 내용
- ☞ 점검 방법 및 절차
- ☞ 점검 결과 기록 및 보관
- ☞ 점검 결과 후속조치(개선, 보고) 등

사례로 살펴보는 개인정보 안전관리 등



안전성 확보조치 위반사례

법령

▶ 제4조(내부 관리계획의 수립·시행)

- ① 개인정보처리자는 개인정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 **다음 각 호의 사항을 포함하는 내부 관리계획을 수립·시행**하여야 한다. 다만, 1만명 미만의 정보주체에 관하여 개인정보를 처리하는 소상공인·개인·단체의 경우에는 생략할 수 있다.

위반사례

개인정보보호를 위한 내부관리계획 및 관련 문서
(내부 승인문서)

12.1.1 의무기록관리규정			
관리번호		제정일	2014. 4. 1
승인책임자		시행일	2014. 4. 1
검토책임자		개정일	2014. 4. 1
담당부서(자)		검토주기	2년
관련근거		검토예정일	2016. 4. 1

제9조 [사본발급]

1. 의료법 제 21조 및 시행규칙에 근거하여 사본을 발급한다.
2. 환자의 개인정보보호를 위하여 사본발급시 환자의 주치의 승인을 받아야 한다.
(부록이관 경우 해당과 의사)

12.1.3 접근권한 관리지침			
관리번호		제정일	2014. 4. 1
승인책임자		시행일	2014. 4. 1
검토책임자		개정일	2014. 4. 1
담당부서(자)		검토주기	2년
관련근거		검토예정일	2016. 4. 1

제1조 [목적]

이 지침은 의료정보의 작성, 조회 및 검색할 수 있는 권한을 적정범로 구분하고 의료정보의 접근권한을 명확히 하여 환자의 개인정보를 보호하고 안전하게 관리함을 목적으로 한다.

12.1.4 의무기록 사본발급 지침			
관리번호		제정일	2014. 4. 1
승인책임자		시행일	2014. 4. 1
검토책임자		개정일	2014. 4. 1
담당부서(자)		검토주기	2년
관련근거		검토예정일	2016. 4. 1

제1조 [목적]

이 지침은 「의료법」 및 「개인정보 보호법」에 근거하여 의무기록의 열람 및 사본 발급의 목적, 요건, 절차 등을 규정함으로써 의무기록의 기밀성 확보를 목적으로 한다.

12.1.5 의무기록 대출·열람 및 반납 지침			
관리번호		제정일	2014. 4. 1
승인책임자		시행일	2014. 4. 1
검토책임자		개정일	2014. 4. 1
담당부서(자)		검토주기	2년
관련근거		검토예정일	2016. 4. 1

제1조 [목적]

이 지침은 의무기록의 소재지 파악을 명확하게 하여 이용의 효율성을 도모하고 의무기록 관리규정에서 정의한 목적 이외의 정보누출을 방지할 수 있도록 안전하게 관리하는 것을 목적으로 한다.

내부 관리계획에 개인정보의 안전성 확보에 필요한 조치에 관한 사항 미 포함

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제4조(내부 관리계획의 수립·시행)

- ① 개인정보처리자는 개인정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 **다음 각 호의 사항을 포함하는 내부 관리계획을 수립·시행**하여야 한다. 다만, 1만명 미만의 정보주체에 관하여 개인정보를 처리하는 소상공인·개인·단체의 경우에는 생략할 수 있다.

개선조치

<내부관리계획>

1. 개인정보 보호 조직의 구성 및 운영에 관한 사항	9. 악성프로그램 등 방지에 관한 사항
2. 개인정보 보호책임자의 자격요건 및 지정에 관한 사항	10. 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항
3. 개인정보 보호책임자와 개인정보취급자의 역할 및 책임에 관한 사항	11. 물리적 안전조치에 관한 사항
4. 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항	12. 개인정보 유출사고 대응 계획 수립·시행에 관한 사항
5. 접근 권한의 관리에 관한 사항	13. 위험 분석 및 관리에 관한 사항
6. 접근 통제에 관한 사항	14. 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항
7. 개인정보의 암호화 조치에 관한 사항	15. 개인정보 내부 관리계획의 수립, 변경 및 승인에 관한 사항
8. 접속기록 보관 및 점검에 관한 사항	16. 그 밖에 개인정보 보호를 위하여 필요한 사항

☞ 내부관리계획 각 호에 중요한 변경이 있는 경우 즉시 내부 관리계획을 **수정/시행/이력 관리**

☞ CPO는 접근 권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 내부 관리계획의 이행 실태를 **연1회 이상 점검·관리**

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제5조(접근 권한의 관리)

- ③ 개인정보처리자는 제1항 및 제2항에 의한 **권한 부여, 변경 또는 말소에 대한 내역**을 기록하고, 그 기록을 **최소 3년간 보관**하여야 한다.

위반사례

SQL New 1 * +

01020304050607080

11
12 se
13 f:
14 w:
15 o:
16
17
18 SQL
19 fr
20 wh

Script Output

Messages | Data Grid | Trace | DBMS Output | Query Viewer | Explain Plan | Script Output

Output | Grid 1 | Environment

SEQ	MENU	CRUD	CRUD_CONTS	USER_ID	REG_DATE	IP	USER_NM	
719	2	U	ac	직원정보 수정 이름 변경(null	ad	01-6-16	21	adr
718	2	U	ac	직원정보 수정 이름 변경(null	ad	01-6-16	21	adr
676	2	U	ac	직원정보 수정 이름 변경(null	ad	11-5-16	21	adr
675	2	U	ac	직원정보 수정 이름 변경(null	ad	11-5-16	21	adr
674	2	U	ac	직원정보 수정 총괄관리자	ad	11-5-16	21	adr
673	2	U	ac	직원정보 수정 총괄관리자	ad	11-5-16	21	adr
672	2	U	ac	직원정보 수정 이름 변경(null	ad	11-5-16	21	adr
636	2	U	ac	직원정보 수정 이름 변경(null	ad	19-4-16	21	adr
606	2	U	ac	직원정보 수정 이름 변경(null	ad	29-3-16	21	adr
79	2	U	ac	직원정보 수정 이름 변경(adm	ad	25-6-15	21	adr
78	2	U	07	직원정보 수정 총괄관리자 ...	ad	24-6-15	21	adr
77	2	U	ac	직원정보 수정 총괄관리자 ...	ad	24-6-15	21	adr
64	2	U	ac	직원정보 수정 이름 변경(ad...	ad	24-6-15	21	adr
63	2	U	ac	직원정보 수정 이름 변경(ad...	ad	24-6-15	21	adr
62	2	U	ac	직원정보 수정 이름 변경(우...	ad	24-6-15	21	adr

SQL New 1 * +

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제5조(접근 권한의 관리)

- ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 **인증수단**을 **안전**하게 적용하고 관리하여야 한다.

위반사례

일반회원 암호변경

"123"으로 변경 가능

일반회원 아이디

TestID

기존 비밀번호

...

변경 비밀번호

...

변경 비밀번호 확인

...

수정

취소

비밀번호 작성규칙을 시스템에 적용하지 않음

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제5조(접근 권한의 관리)

- ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 **인증수단**을 **안전**하게 적용하고 관리하여야 한다.

개선조치

일반회원 암호변경

일반회원 아이디

TestID

기존 비밀번호

...

입력 비밀번호 : 123

변경 비밀번호

...

*영문, 숫자, 특수문자를 혼합하여 8자리 이상 입력하세요.

변경 비밀번호 확인

...

수정

취소

웹 페이지 메시지

X



비밀번호는 영문, 숫자, 특수문자를 포함하여 8자리 이상으로 구성해야 합니다. 자세한 내용은 [비밀번호 생성규칙]을 확인바랍니다.

확인

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

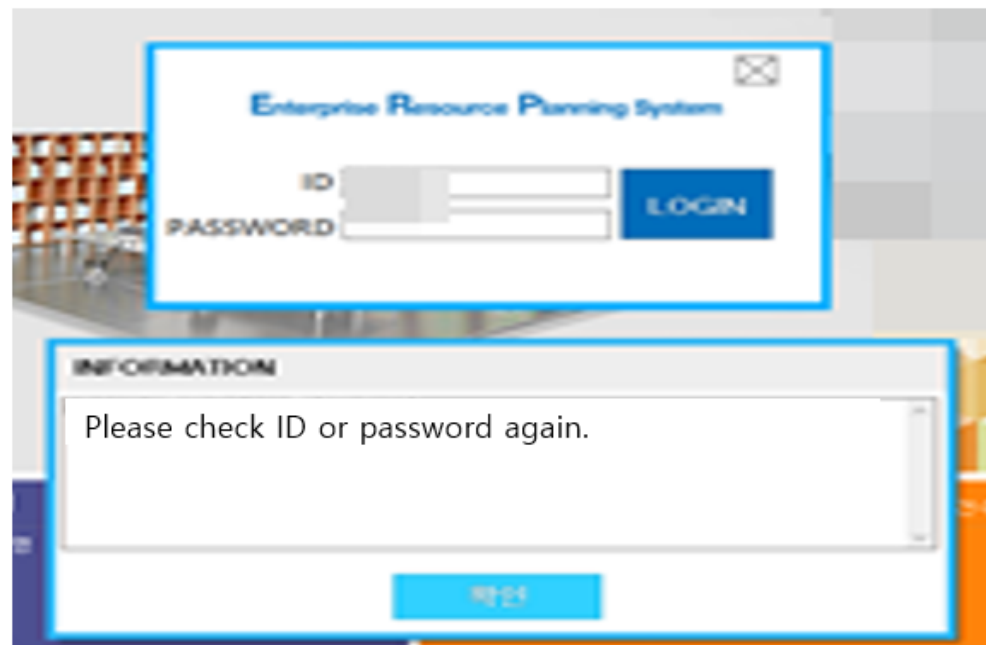
법령

▶ 제5조(접근 권한의 관리)

- ⑥ 개인정보처리자는 정당한 권한을 가진 개인정보취급자 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 **일정 횟수 이상 인증에 실패한 경우** 개인정보처리시스템에 대한 **접근을 제한하는 등** 필요한 조치를 하여야 한다.

위반사례

5회 오류



비밀번호 일정횟수 이상 잘못입력 시 접근제한 등 조치하지 않음

사례로 살펴보는 개인정보 안전관리 등

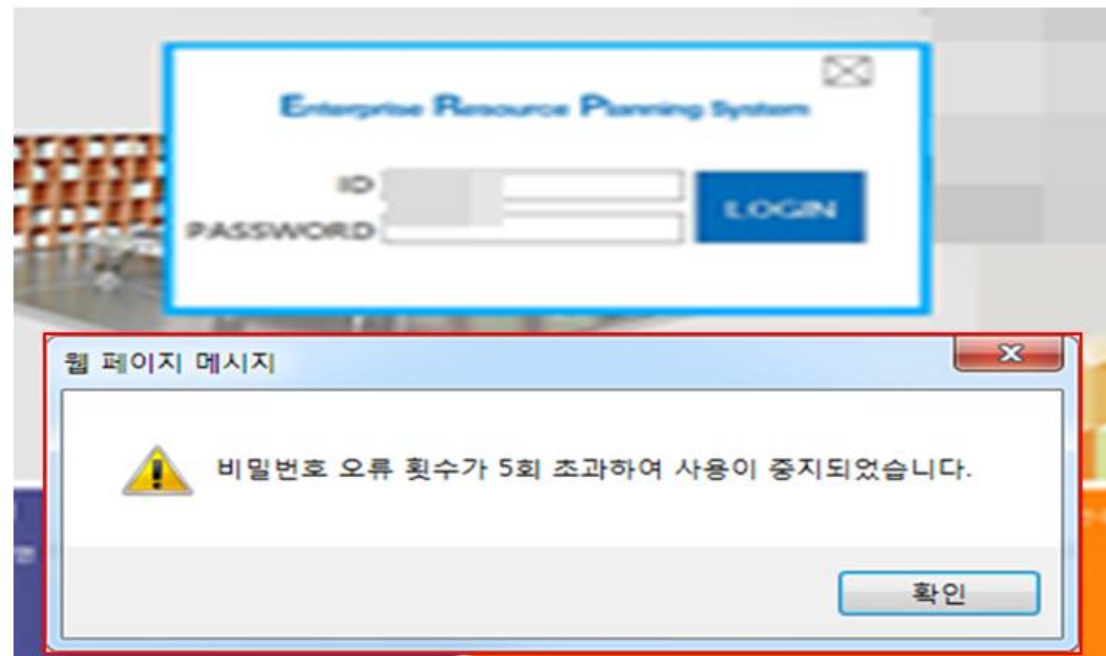
안전성 확보조치 위반사례

법령

▶ 제5조(접근 권한의 관리)

- ⑥ 개인정보처리자는 정당한 권한을 가진 개인정보취급자 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 **일정 횟수 이상 인증에 실패한 경우** 개인정보처리시스템에 대한 **접근을 제한하는 등** 필요한 조치를 하여야 한다.

개선조치



사례로 살펴보는 개인정보 안전관리 등

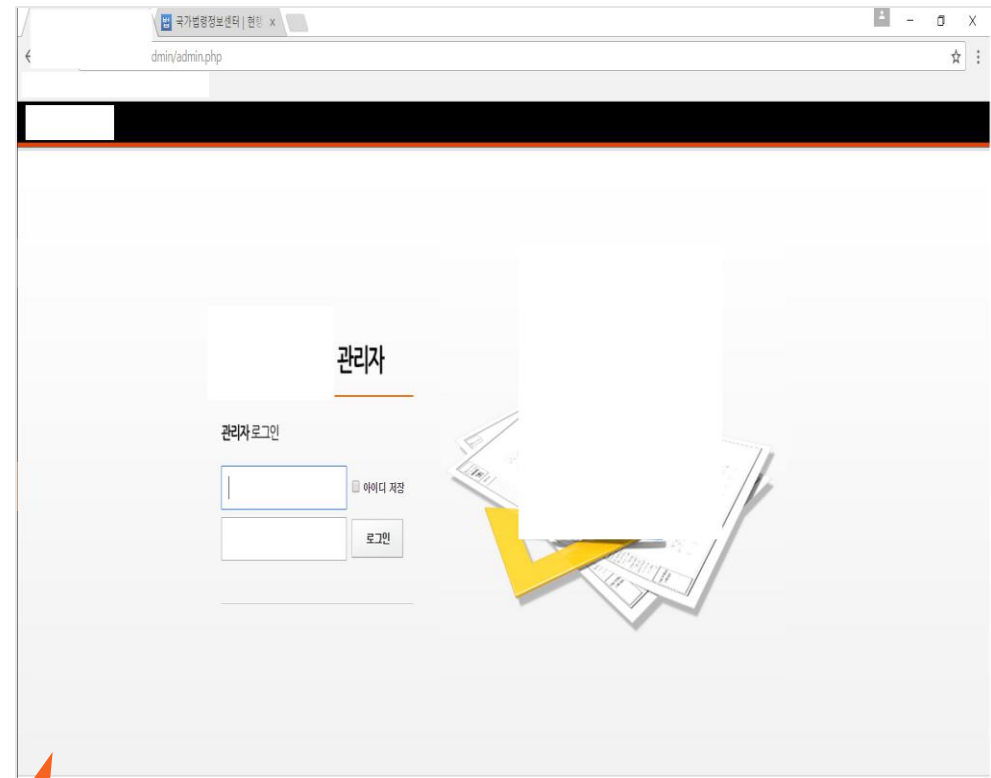
안전성 확보조치 위반사례

법령

▶ 제6조(접근통제)

- ② 개인정보처리자는 개인정보취급자가 정보통신망을 통해 **외부에서 개인정보처리시스템에 접속**하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 **안전한 인증수단**을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 **안전한 접속수단** 또는 **안전한 인증수단**을 적용할 수 있다.

위반사례



외부에서 개인정보처리시스템 접속 시
안전한 접속수단 및 인증수단을 사용하고 있지 않음

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제6조(접근통제)

- ② 개인정보처리자는 개인정보취급자가 정보통신망을 통해 **외부에서 개인정보처리시스템에 접속**하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 **안전한 인증수단**을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 **안전한 접속수단** 또는 **안전한 인증수단**을 적용할 수 있다.

개선조치



The screenshot shows a web browser window with the address bar displaying `https://www.vpnlogin.com/`. The browser tab is titled "VPN login". The page content features the heading "VPN 로그인" (VPN Login) followed by a login form. The form includes a smartphone icon with a lock symbol, two input fields labeled "아이디" (ID) and "비밀번호" (Password), and a blue "Login" button. The page is framed by horizontal blue lines.

사례로 살펴보는 개인정보 안전관리 등

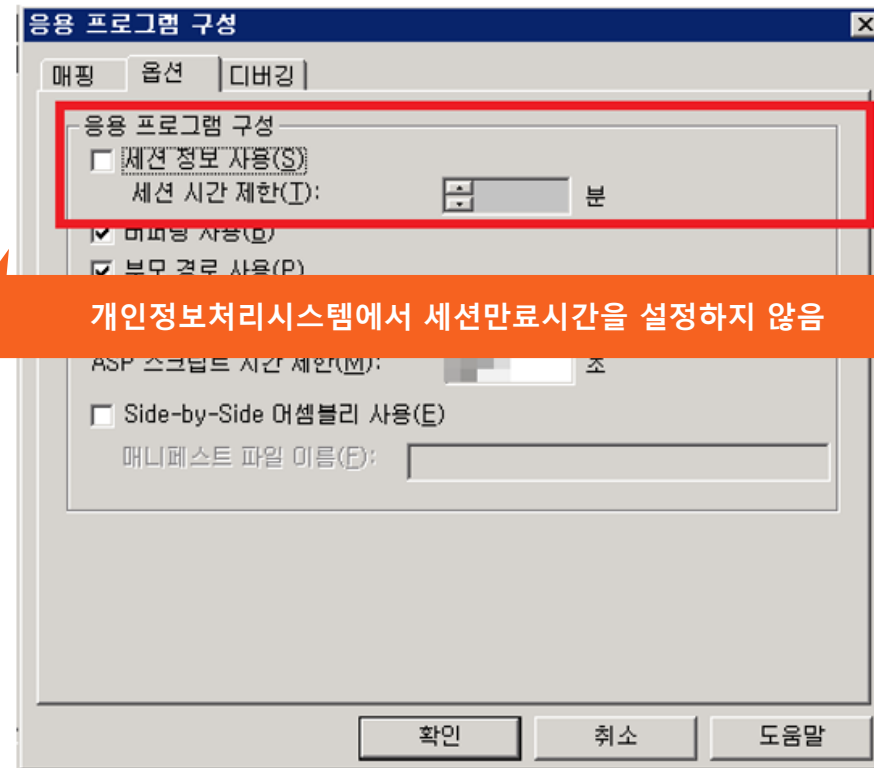
안전성 확보조치 위반사례

법령

▶ 제6조(접근통제)

- ④ 개인정보처리자는 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 **일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 시스템 접속이 차단**되도록 하는 등 필요한 조치를 하여야 한다.

위반사례



개인정보처리시스템에서 세션만료시간을 설정하지 않음

사례로 살펴보는 개인정보 안전관리 등

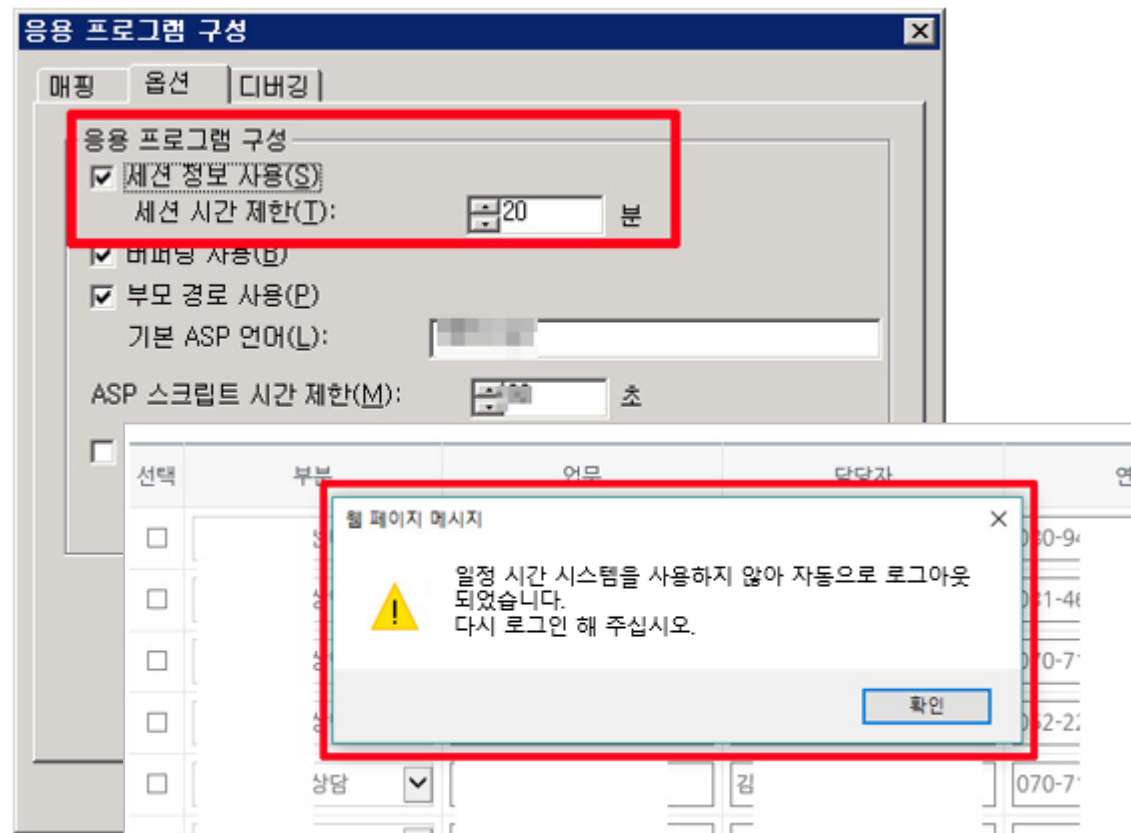
안전성 확보조치 위반사례

법령

▶ 제6조(접근통제)

- ④ 개인정보처리자는 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 **일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 시스템 접속이 차단**되도록 하는 등 필요한 조치를 하여야 한다.

개선조치



사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

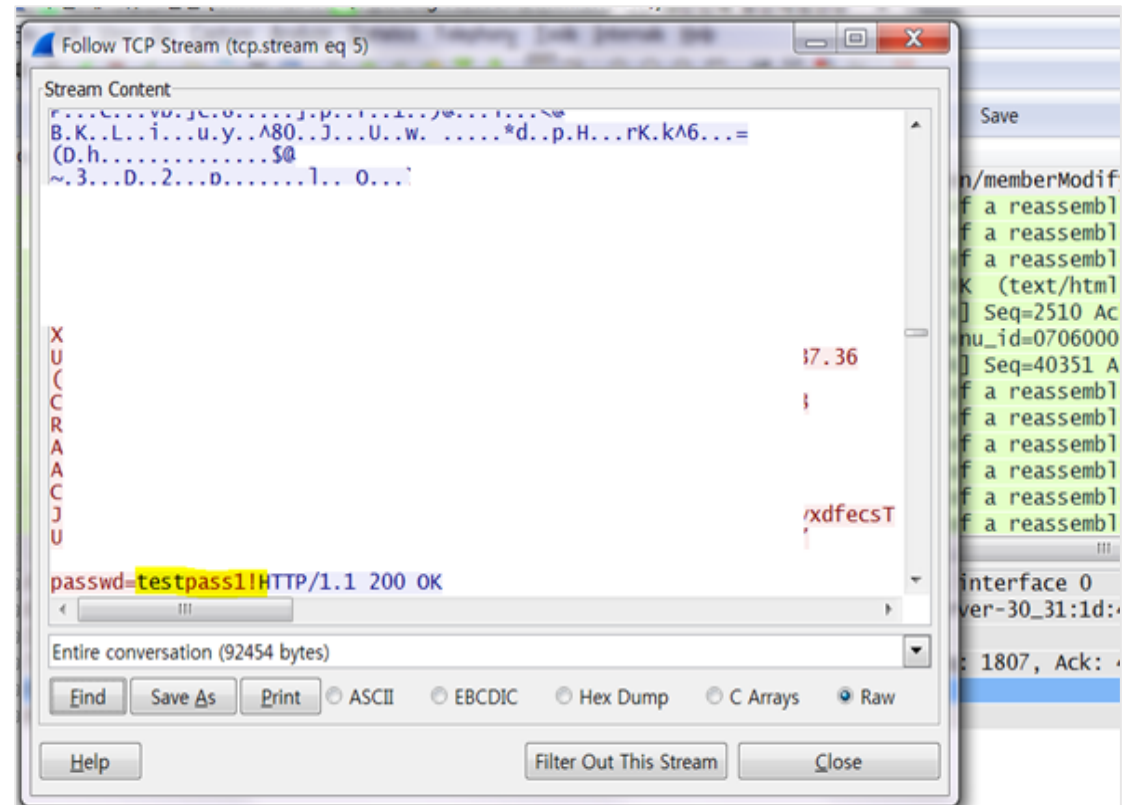
법령

▶ 제7조(개인정보의 암호화)

- ① 개인정보처리자는 **비밀번호, 생체인식정보 등 인증정보를 저장** 또는 정보통신망을 통하여 **송·수신**하는 경우에 이를 안전한 암호 알고리즘으로 **암호화**하여야 한다. 다만, **비밀번호를 저장**하는 경우에는 복호화되지 아니하도록 **일방향 암호화**하여 저장하여야 한다.

정보통신망을 통하여 비밀번호 송·수신 시 암호화 하지 않음

위반사례



사례로 살펴보는 개인정보 안전관리 등

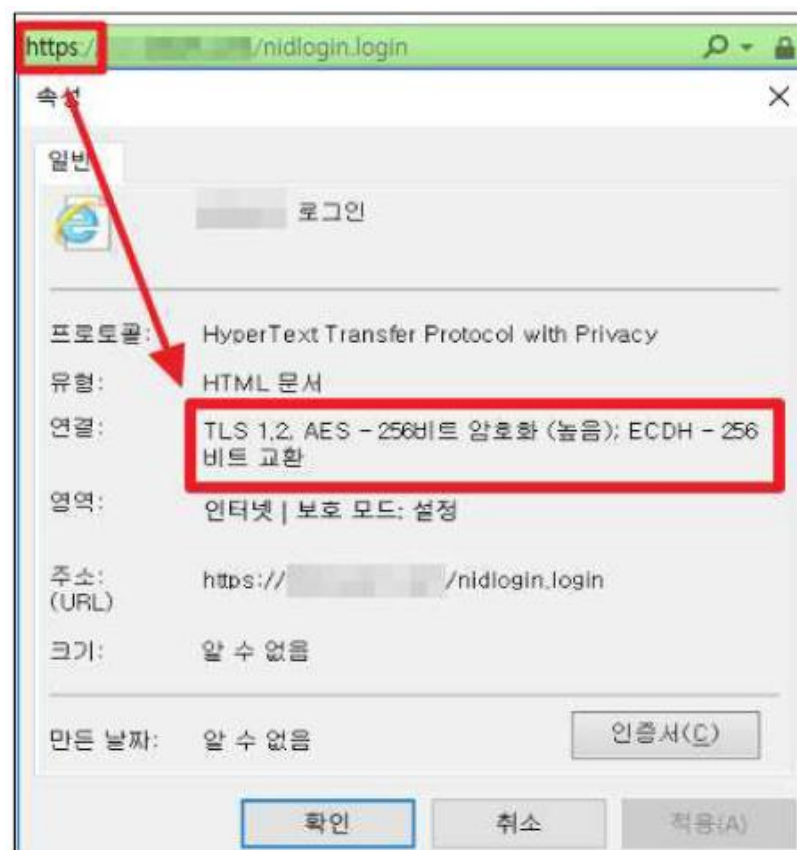
안전성 확보조치 위반사례

법령

▶ 제7조(개인정보의 암호화)

- ① 개인정보처리자는 **비밀번호, 생체인식정보 등 인증정보를 저장** 또는 정보통신망을 통하여 **송·수신**하는 경우에 이를 안전한 암호 알고리즘으로 **암호화**하여야 한다. 다만, **비밀번호를 저장**하는 경우에는 복호화되지 아니하도록 **일방향 암호화**하여 저장하여야 한다.

개선조치



사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제7조(개인정보의 암호화)

- ① 개인정보처리자는 **비밀번호, 생체인식정보 등 인증정보를 저장** 또는 정보통신망을 통하여 **송·수신**하는 경우에 이를 안전한 암호 알고리즘으로 **암호화**하여야 한다. 다만, **비밀번호를 저장**하는 경우에는 복호화되지 아니하도록 **일방향 암호화**하여 저장하여야 한다.

위반사례

AID	PWD	ANAME	ACOMPANY	ATEAM	EMAIL	PHONE1	PHONE2	PHONE3
1001	57123456	김민준	아메리카	34	1001@america.com	010	1234	5678
1002	23456789	권민준	아메리카	21	1002@america.com	02	1234	5678
1003	dv123456	강민준	아메리카	34	1003@america.com	02	1234	5678
1004	P1234567	장민준	아메리카	4	1004@america.com	02	1234	5678
1005	56789012	김민준	아메리카	4	1005@america.com	02	1234	5678
1006	12345678	상민준	아메리카	4	1006@america.com	02	1234	5678
1007	E1234567	김민준	아메리카	4	1007@america.com	02	1234	5678

PW 평문저장

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제7조(개인정보의 암호화)

- ① 개인정보처리자는 **비밀번호, 생체인식정보 등 인증정보를 저장** 또는 정보통신망을 통하여 **송·수신**하는 경우에 이를 안전한 암호 알고리즘으로 **암호화**하여야 한다. 다만, **비밀번호를 저장**하는 경우에는 복호화되지 아니하도록 **일방향 암호화**하여 저장하여야 한다.

개선조치

AID	PWD	ANAME	ACOMPANY	ATE
	64624864b54		아	3
	4a7d1ed471		아	2
	4e71ed14347		아	3
	2a4s56dwq45		아	4
	d546a4d56a4		아	4
	wdq8a58a88a		아	4

다운로드

- 동영상
- 문서
- 바탕 화면
- 사진
- 음악
- 로컬 디스크 (C:)

파일 이름(N): 회원정보(주민등록번호).xlsx

파일 형식(T): Excel 통합 문서 (*.xlsx)

만든 이: Windows 사용자

☐ 축소판 그림 저장

일반 옵션 ? X

☐ 백업 파일 항상 만들기(B)

파일 공유

열기 암호(O):

쓰기 암호(M):

☐ 읽기 전용 권장(R)

확인 취소

도구(L) 저장(S) 취소

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제8조(접속기록의 보관 및 점검)

- ① 개인정보처리자는 개인정보취급자의
**개인정보처리시스템에 대한 접속기록을 1년 이상
 보관·관리**하여야 한다. 다만, 다음 각 호의 어느 하나에
 해당하는 경우에는 2년 이상 보관·관리하여야 한다.

▶ 제2조(정의)

- ⑫ "접속기록"이란 개인정보취급자 등이
 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여
**개인정보취급자 등의 계정, 접속일시, 접속지 정보, 처리한
 정보주체 정보, 수행업무** 등을 전자적으로 기록한 것을
 말한다. 이 경우 "접속"이란 개인정보처리시스템과 연결되어
 데이터 송신 또는 수신이 가능한 상태를 말한다.

위반사례

1	사이트명	카탈	ip	referer	agent	os	device	접속일시	
2		5				E 7	Windows XP	Other	20160324125109
3		4				0	Android	SM-P900	20160324124408
4		3				T	Windows 7	Other	20160324124310
5		2				0	Android	SM-G900L	20160324124303
6		1				0	Windows	Other	20160324124150
7		0				E 7	Windows 7	Other	20160324124056
8		9				0	Windows	Other	20160324123835
9		8				T	Windows 7	Other	20160324123749
10		7				E 9	Windows 7	Other	20160324123626
11		6				A	Android	SAMSUNG SM-N900S	20160324123306
12		5				1	Android	SM-J500N0	20160324123301
13		4				1	Android	SM-N916K	20160324122753
14		3				T	Windows 7	Other	20160324121904
15		2				V	Windows	Other	20160324121615
16		1				on	iOS	iPhone	20160324121611
17		0				on	iOS	iPhone	20160324121532
18		9				V	Windows 7	Other	20160324121327
19		8				T	Windows 7	Other	20160324120722
20		7				0	Android	SAMSUNG SM-N900S	20160324120355

수행업무에 대한 접속 기록을 보관하고 있지 않음

사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제8조(접속기록의 보관 및 점검)

- ① 개인정보처리자는 개인정보취급자의
**개인정보처리시스템에 대한 접속기록을 1년 이상
 보관·관리**하여야 한다. 다만, 다음 각 호의 어느 하나에
 해당하는 경우에는 2년 이상 보관·관리하여야 한다.

▶ 제2조(정의)

- ①9 "접속기록"이란 개인정보취급자 등이
 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여
**개인정보취급자 등의 계정, 접속일시, 접속지 정보, 처리한
 정보주체 정보, 수행업무** 등을 전자적으로 기록한 것을
 말한다. 이 경우 "접속"이란 개인정보처리시스템과 연결되어
 데이터 송신 또는 수신이 가능한 상태를 말한다.

개선조치

os	id	work	device	접속일시
Windows XP		조회	Other	20160324125109
Android		삭제	SM-P900	20160324124408
Windows 7		추가	Other	20160324124310
Android		추가	SM-G900L	20160324124303
Windows		삭제	Other	20160324124150
Windows 7		갱신	Other	20160324124056
Windows		조회	Other	20160324123835
Windows 7		추가	Other	20160324123749
Windows 7		갱신	Other	20160324123626
Android		삭제	SAMSUNG SM-N900S	20160324123306
Android		추가	SM-J500ND	20160324123301
Android		추가	SM-N916K	20160324122753
Windows 7		추가	Other	20160324121904
Windows		갱신	Other	20160324121615
iOS		조회	iPhone	20160324121611
iOS		종료	iPhone	20160324121532
Windows 7		종료	Other	20160324121327
Windows 7		갱신	Other	20160324120722
Android		갱신	SAMSUNG SM-N900S	20160324120355

사례로 살펴보는 개인정보 안전관리 등

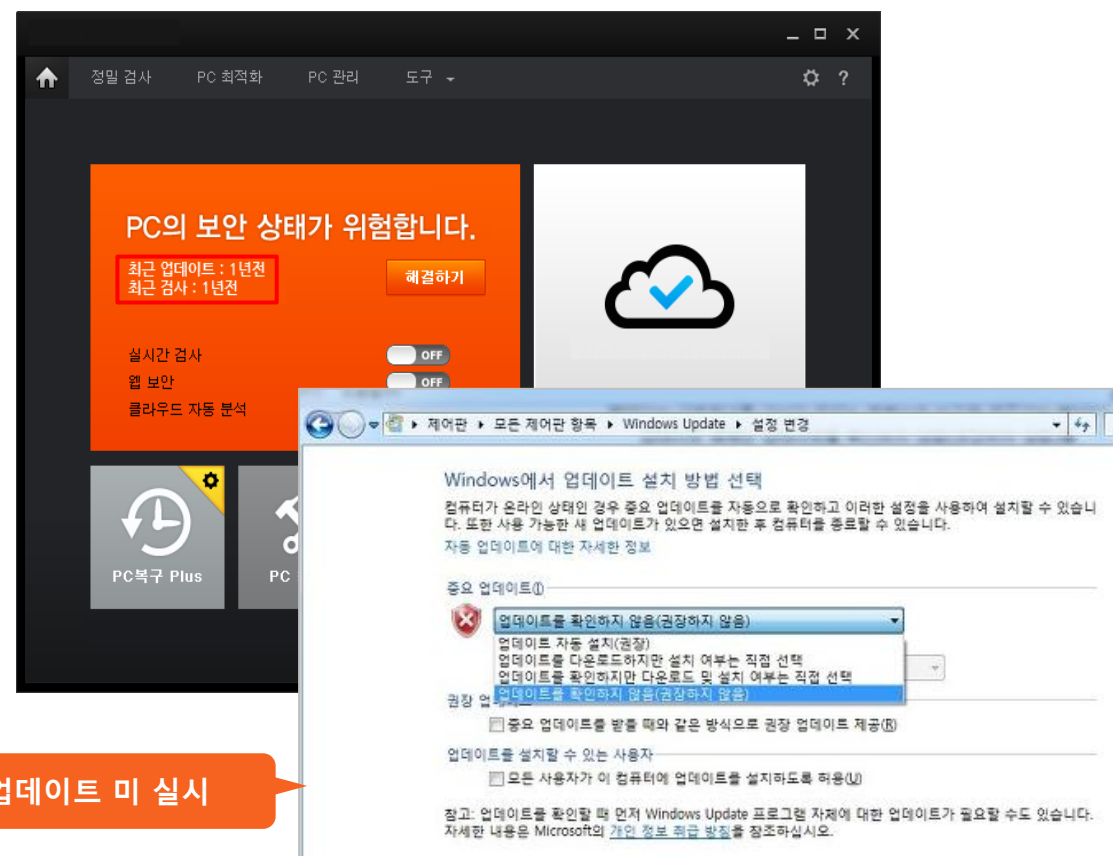
안전성 확보조치 위반사례

법령

▶ 제9조(악성프로그램 등 방지)

- 개인정보처리자는 악성프로그램 등을 방지치료할 수 있는 보안 프로그램을 설치운영하여야 하며, 다음 각 호의 사항을 준수하여야 한다.
 - 프로그램의 **자동 업데이트 기능을 사용하거나, 정당한 사유가 없는 한 일 1회 이상 업데이트를 실시하여 최신의 상태로 유지**
 - 발견된 악성프로그램 등에 대해 삭제 등 대응 조치
- 악성프로그램 관련 경보가 발령된 경우 또는 **사용 중인 응용 프로그램이나 운영체제 소프트웨어의 제작업체에서 보안 업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트를 실시**

위반사례



백신 소프트웨어 업데이트 미 실시

사례로 살펴보는 개인정보 안전관리 등

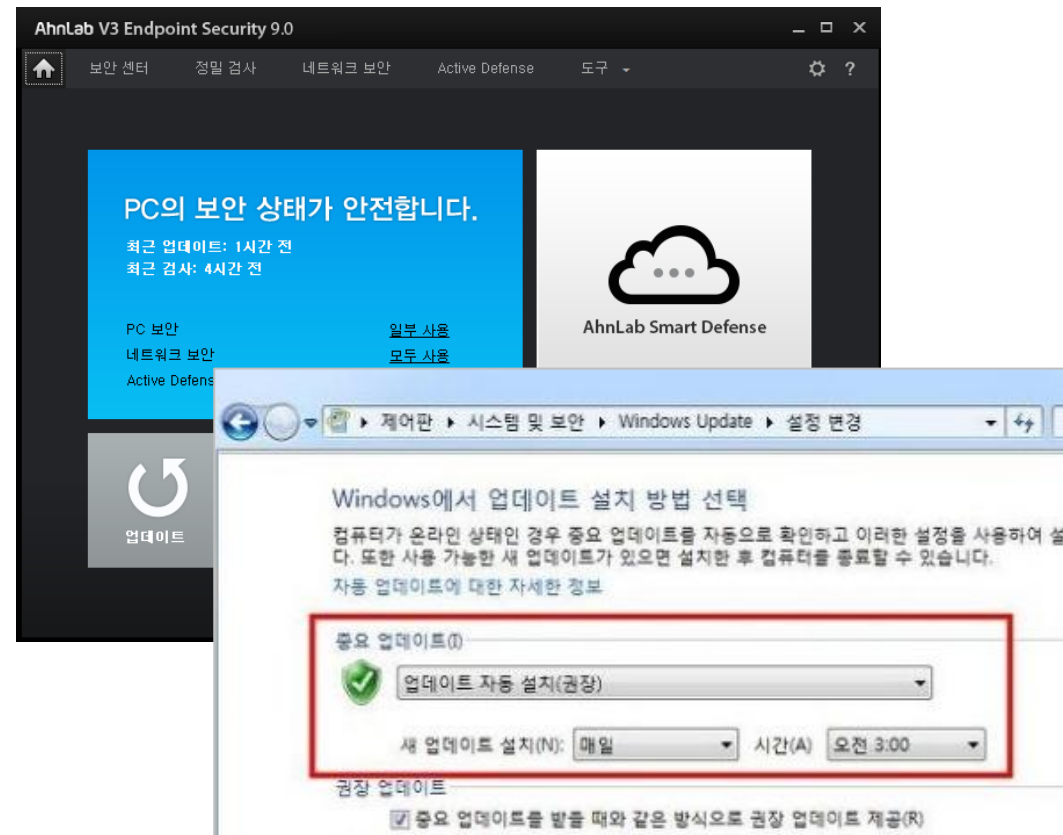
안전성 확보조치 위반사례

법령

▶ 제9조(악성프로그램 등 방지)

- 개인정보처리자는 악성프로그램 등을 방지치료할 수 있는 보안 프로그램을 설치운영하여야 하며, 다음 각 호의 사항을 준수하여야 한다.
 - 프로그램의 **자동 업데이트 기능을 사용하거나, 정당한 사유가 없는 한 일 1회 이상 업데이트를 실시하여 최신의 상태로 유지**
 - 발견된 악성프로그램 등에 대해 삭제 등 대응 조치
- 악성프로그램 관련 경보가 발령된 경우 또는 **사용 중인 응용 프로그램이나 운영체제 소프트웨어의 제작업체에서 보안 업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트를 실시**

개선조치



사례로 살펴보는 개인정보 안전관리 등

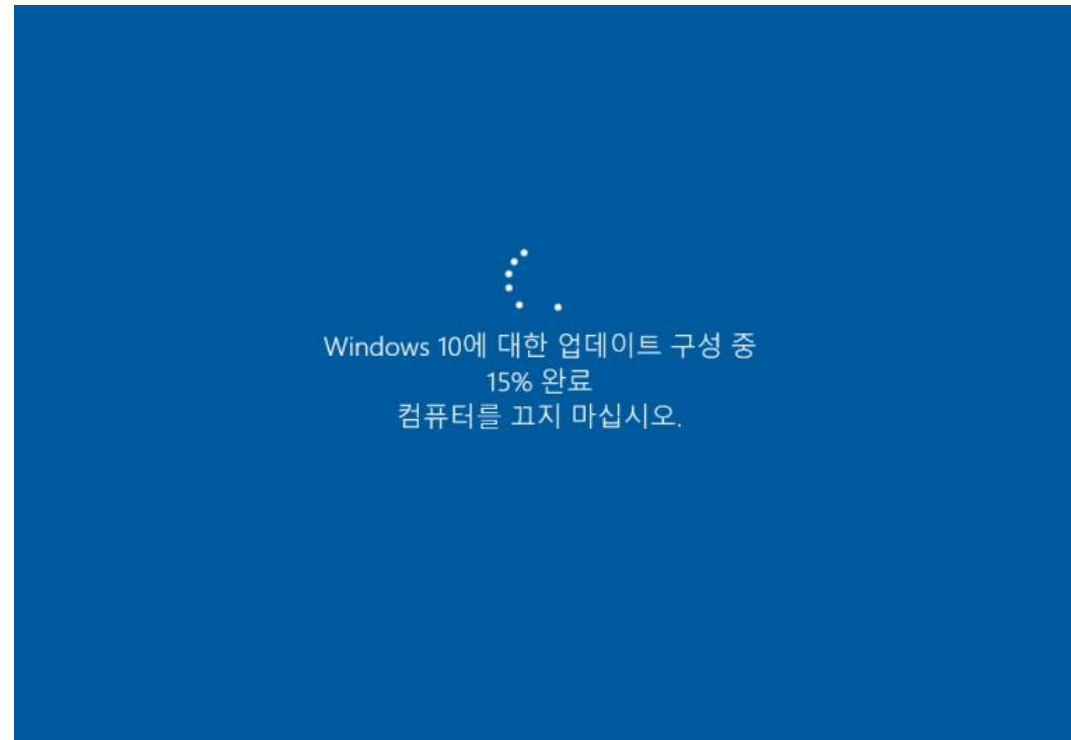
안전성 확보조치 위반사례

법령

▶ 제9조(악성프로그램 등 방지)

- 개인정보처리자는 악성프로그램 등을 방지치료할 수 있는 보안 프로그램을 설치운영하여야 하며, 다음 각 호의 사항을 준수하여야 한다.
 1. 프로그램의 **자동 업데이트 기능을 사용하거나, 정당한 사유가 없는 한 일 1회 이상 업데이트를 실시하여 최신의 상태로 유지**
 2. 발견된 악성프로그램 등에 대해 삭제 등 대응 조치
- 악성프로그램 관련 경보가 발령된 경우 또는 **사용 중인 응용 프로그램이나 운영체제 소프트웨어의 제작업체에서 보안 업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트를 실시**

개선조치



사례로 살펴보는 개인정보 안전관리 등

안전성 확보조치 위반사례

법령

▶ 제10조(물리적 안전조치)

- ② 개인정보처리자는 **개인정보가 포함된 서류, 보조저장매체 등을 잠금 장치가 있는 안전한 장소에 보관**하여야 한다.

개인정보가 포함된 서류, 보조저장매체 등을
책상위에 보관하고 있음

위반사례



사례로 살펴보는 개인정보 안전관리 등

개인정보 상담 사례

[임시 개인정보취급자의 사용자 계정 관리]

✓ 상담사항

저는 공공기관에서 임시적으로 개인정보를 입력하고 정리하는 업무를 하고 있습니다.

그런데 업무 담당 직원의 아이디를 이용하여 제가 개인정보를 입력하고 열람할 수 있는데 이 부분은 문제가 되지 않나요?

✓ 상담사례집 답변

- 별도의 개인정보처리시스템 사용자 계정을 발급하여야 하고, 업무 담당 직원의 사용자 계정을 공유하여서는 안 됩니다.
- 이 사례의 경우 한시적으로 개인정보 입력 및 정리 업무를 하는 자는 개인정보취급자에 해당될 수 있으므로 별도의 개인정보처리시스템의 사용자 계정을 발급하여야 하고 업무 담당 직원의 사용자 계정을 공유하여서는 안 됩니다. **단, 정당한 사유가 있다면 공유도 가능합니다.** (안전성 확보조치 제5조 4항에 따라 정당한 사유가 있을 시 내부관리계획에 따라 공유가 가능함)
- 그리고 해당 개인정보취급자의 업무인 개인정보 입력 등의 수행에 필요한 최소한의 범위로 권한을 부여하여야 합니다.



감사합니다

